

IT-Sicherheit - Verschlüsselung

Prof. Dr. Johannes Freudenmann (DHBW Karlsruhe)
Masterprogramm Informatik

www.dhbw.de

Netzwerksicherheit Techniken Verschlüsseln

- Im ISO/OSI-Modell auf jeder Schicht möglich.
- Leitung
- Luftschnittstelle (WEP/WPA-X, GSM/LTE/5G)
- Ende-Ende, IPSec
- TLS – SSL
- SSH
- (Anwendungsebene – Mail, File, ..., -> Straub)

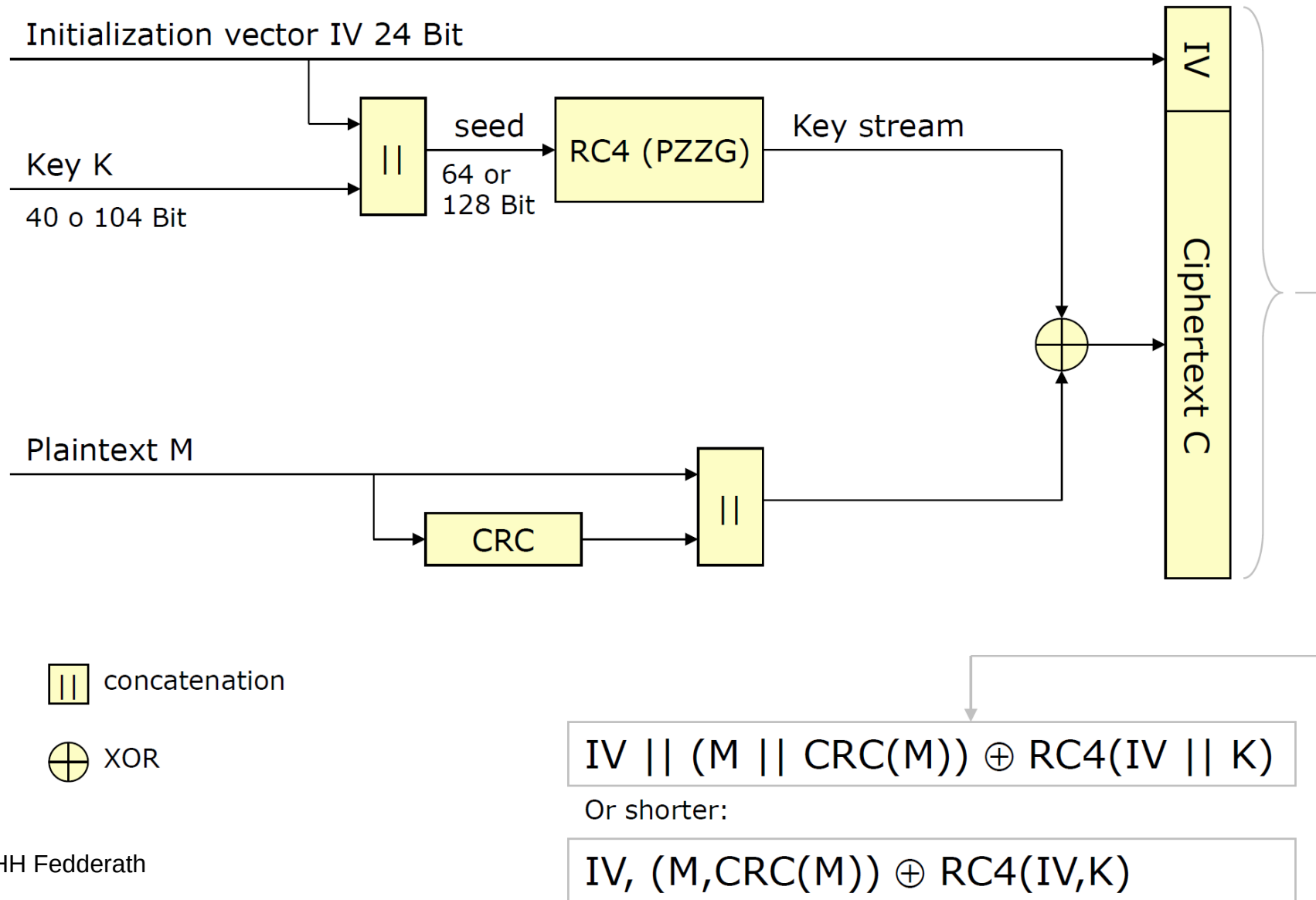
Netzwerksicherheit Techniken Verschlüsseln Leitung

- Verschlüsselungsbox an beiden Enden.
 - Einfache Installation
 - Starker symmetrischer Algorithmus
 - Boxen werden paarweise produziert.
 - Öffnen verhindern, Prozessor gekapselt.
 - Höchste Sicherheitsstufe auch für hohe Sicherheitsanforderungen (Polizei, Nachrichtendienste, Militär)

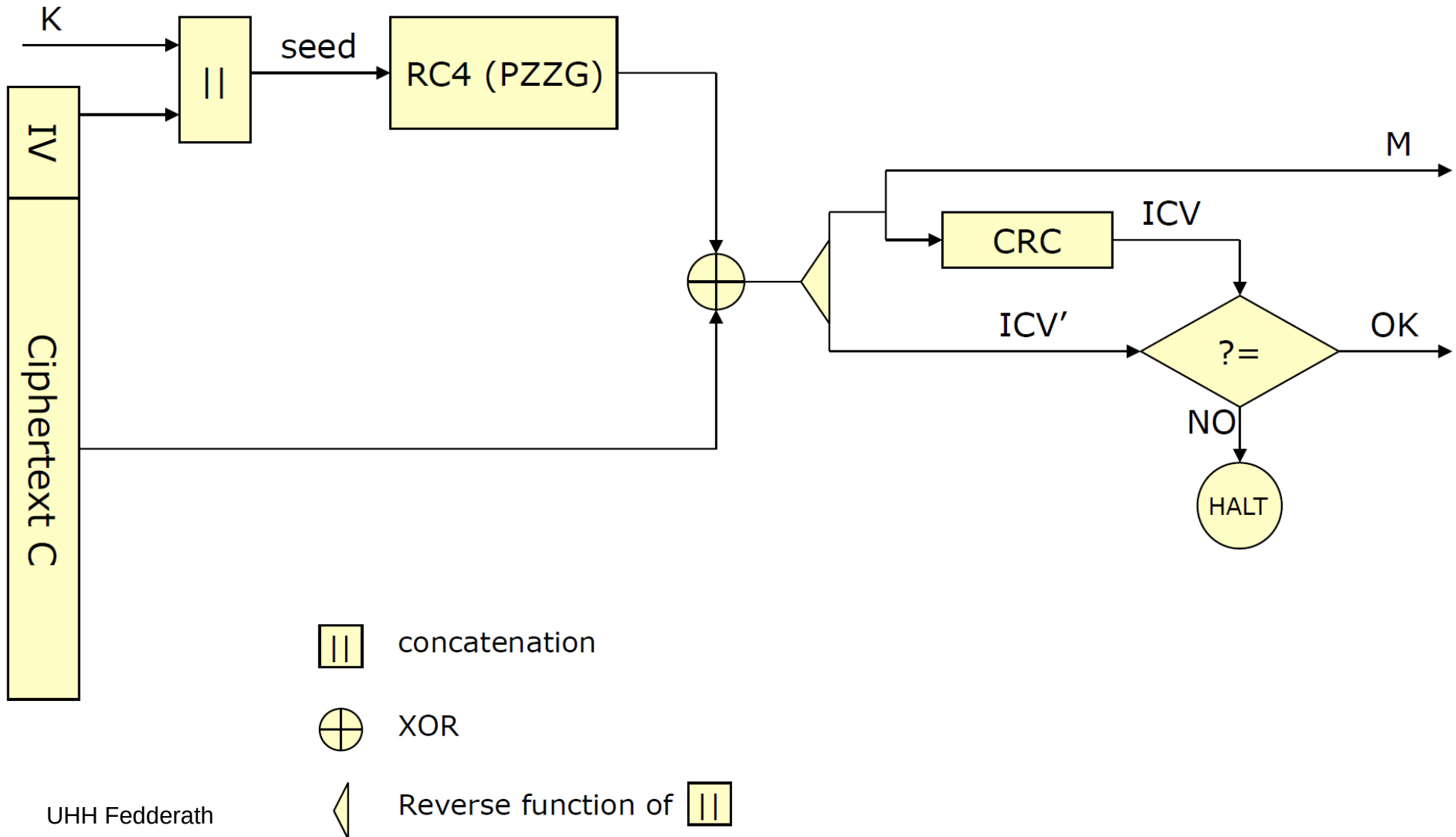
Netzwerksicherheit Techniken Verschlüsseln WLAN/WEP

- Allgemein
 - Optionaler Teil von IEEE 802.11
 - Verschlüsselung, Integrität und Authentizität
 - 1997 eingeführt, in praktisch allen WLAN-Geräten implementiert (inzwischen nicht mehr unterstützt).
- Verschlüsselung
 - Symmetrisch mit 40 oder 104 bit Schlüssel auf Basis RC4
- Integrität durch CRC
- Authentizität
 - Methode 1: keine
 - Methode 2: Challenge-Response mit PSK

Netzwerksicherheit Techniken Verschlüsseln WEP Encrypt



Netzwerksicherheit Techniken Verschlüsseln WEP Decrypt

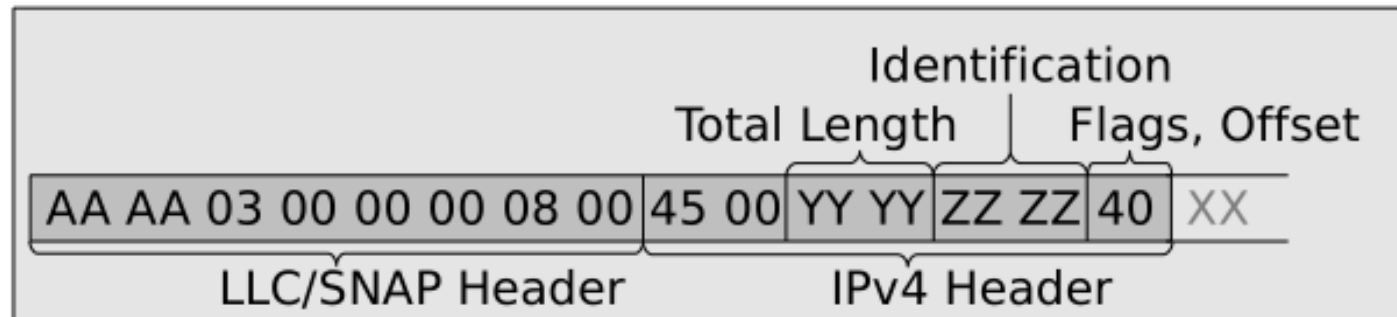


Netzwerksicherheit Techniken Verschlüsseln WEP

- Authentizität wird nur bei shared key geprüft.
 - Challenge vom Access Point
 - Client sendet verschlüsselte Challenge als Response
 - Kein Zugriff bei Fehler.
- Viele Angriffsmöglichkeiten
 - Replay
 - IV zu kurz, zu wenig Alternativen
 - Aus IV und verschlüsselter Nachricht ist key berechenbar (Startet mit SNAP-Pattern 0xAAAA03)
 - Key 40 bit (Brute Force Attack)
- Abgelöst durch WPA (2004), WPA2 bzw. WPA3

Netzwerksicherheit Techniken WEP Angriffe

- Fluhrer, Mantin und Shamir Angriff (2001)
 - ca. 1.000.000 benötigte Pakete
 - Um die 40 Minuten
- Tews, Pychkine und Weinmann Angriff (2007 TU Darmstadt)
 - 40.000 bis 100.000 Pakete
 - 1-2 Minuten



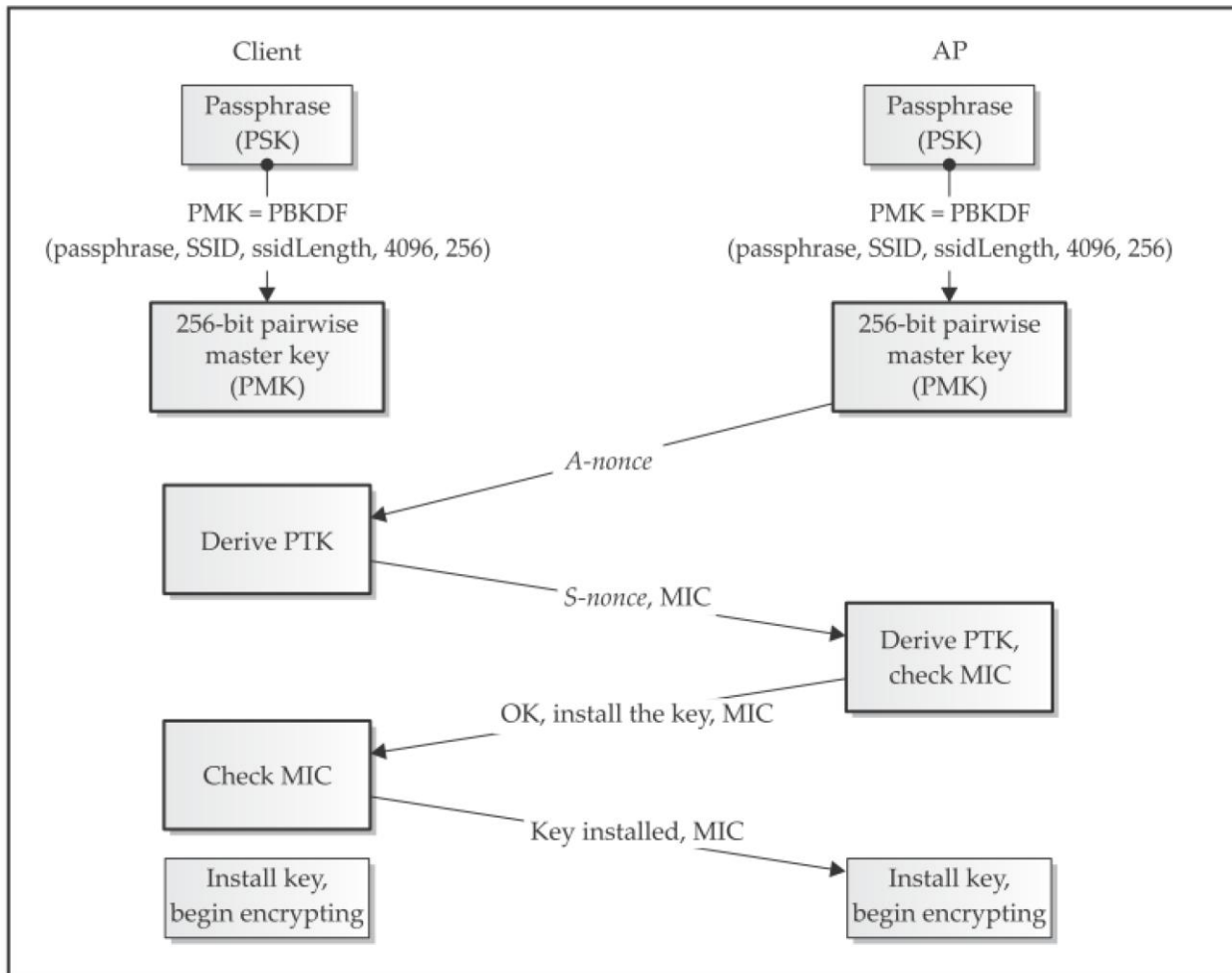
Netzwerksicherheit Techniken WLAN Verschlüsseln WPA

- WEP unsicher
- Neuer Sicherheitsstandard IEEE 802.11i
- 2004 ist WPA Teil des Standards
- Schlüssel dynamisch
TKIP - Temporal Key Integrity Protocol
neuer Schlüssel je Session (3200 sec -120 sec)
- Integrität wird geprüft
MIC - Message Integrity Check
- Authentifizierung
 - PSK – Pre Shared Key
 - EAP - Enterprise Authentication Protocol

WPA-Personal Übersicht

Client authentisiert sich direkt gegenüber AP mit PMK

Four-way handshake (alle Infos ausser SSID)



PSK = 8-63 ASCII Zeichen + Hash

Pairwise Master Key (PMK)
PMK = SSID x PSK + Hash!

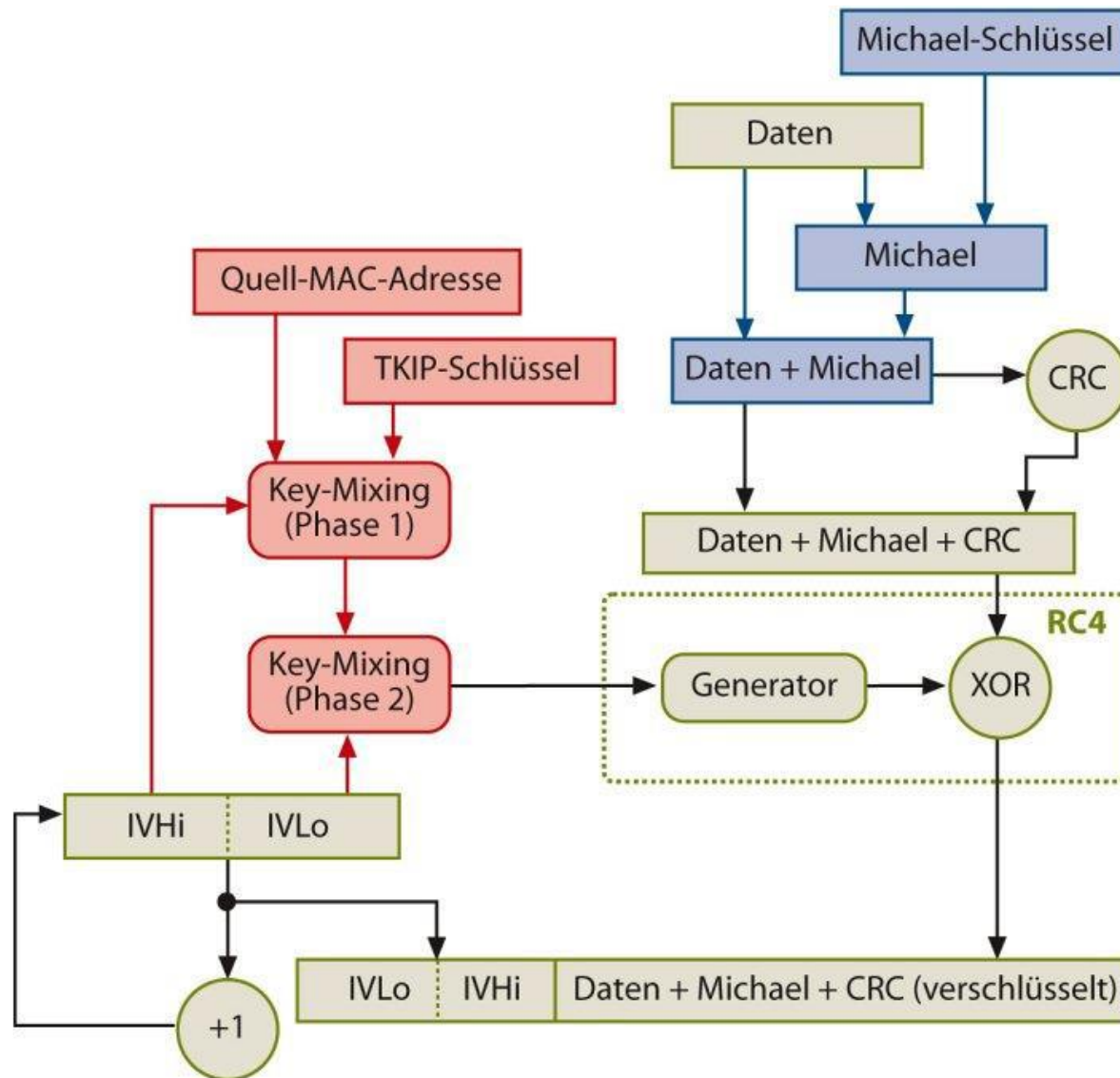
Pairwise Transient Key (PTK)
PTK = PMK, S/A-Nonce, MAC (Client/AP)
PTK = dynamisch
(Anmeldung & periodisch)

Skizze: Belsoft Security

WPA – Zwischenlösung auf dem Weg zu WPA2

- Wenig leistungsfähige AccessPoints durch Software ertüchtigen und WEP ersetzen.
- Schlüssel öfter ersetzen (s. vorige Folie, ca 10.000 Pakete)
- TKIP (Temporal Key Integrity Protocol)
 - MIC ergänzt CRC. Verfahren Michael (geringer Berechnungsaufwand)
 - Längerer IV und Regelungen für die Verwendung auch als Sequenznummer gegen Replay
 - Weiter RC4 genutzt (Schlüssel auf 64 bit beschränkt)
 - Nicht mehr genutzt bei WPA2

WLAN Verschlüsseln WPA



WLAN Verschlüsseln WPA

- Schwachstellen
 - Basis RC4 (Schlüssel nur 64 Bit lang)
 - ARP-Spoofing möglich
 - Angriff auf das Passwort durch Dictionary Attack

Netzwerksicherheit Techniken Verschlüsseln WPA2

- Authentifizierung mit
 - Pre-Shared Key
 - Radius
 - EAP (Extensible Authentication Protocol, RFC5247)
- AES für Verschlüsselung

WPA2 – KRACK Attack

- Angriff auf den 4way Handshake
- KRACK Key Reinstallation attACK.
- Message 3 des Handshake wird wiederholt an den Client gesandt
 - Der gleiche Schlüssel wird neu installiert
 - PacketSendeZähler wird zurückgesetzt
 - EmpfangsReplay Zähler wird zurückgesetzt.
 - Angriffsmöglichkeiten ergeben sich.
- Update des Clients behebt das Problem.
- <https://www.krackattacks.com/>

WPA 3

- Verabschiedet 25. Juni 2018
- Bessere Authentifizierung und Verschlüsselung
- KRACK-Sicherheitslücke behoben durch besseren Handshake
- Höherer Schutz auch bei einfachen Passwörtern
- Einfachere Konfiguration für IoT, z.B. durch QR-Code
- Individuelle Verschlüsselung in öffentlichen Netzen
- Einsatz von 192-bit-Verschlüsselung

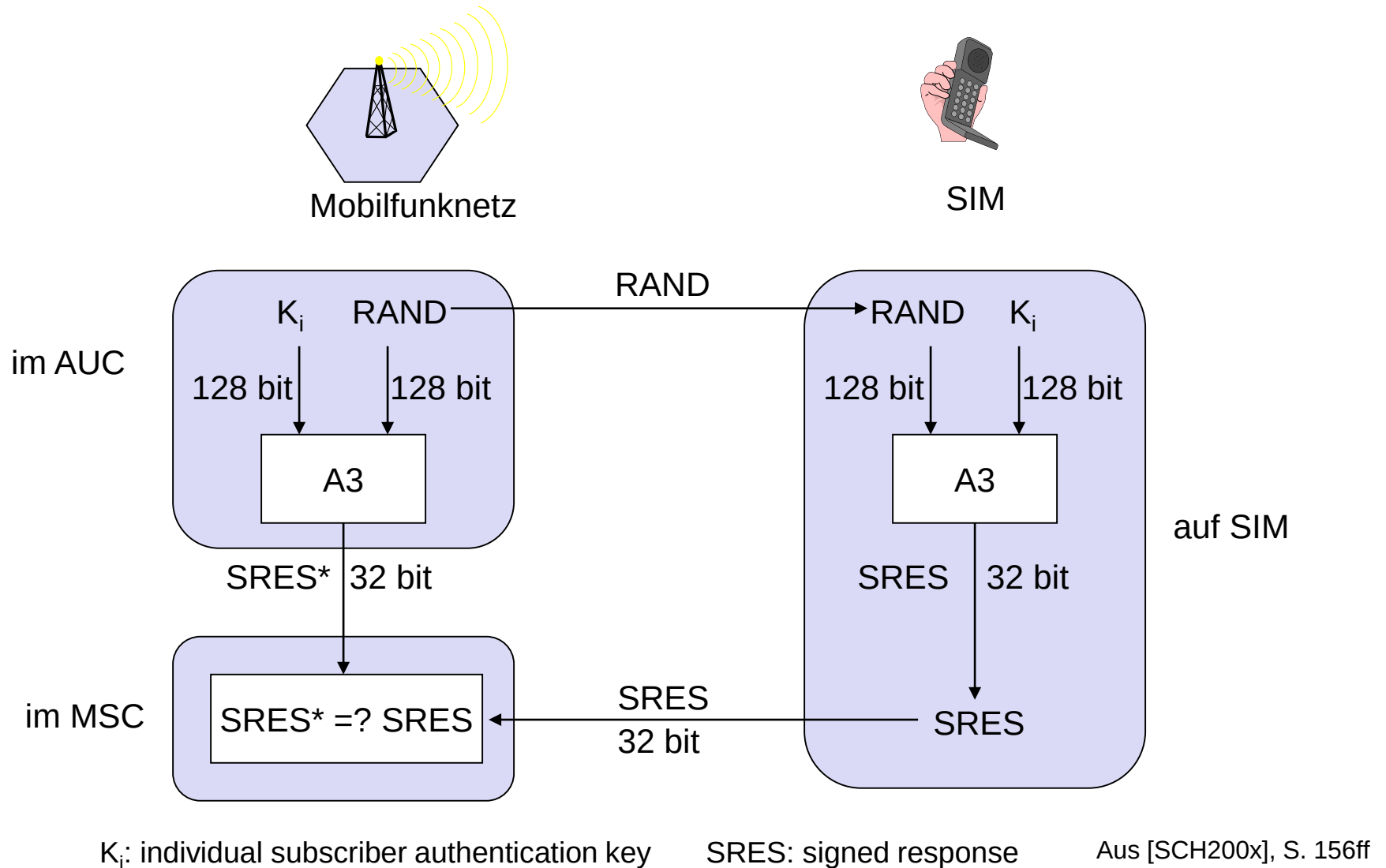
WPA 3

- Höherer Schutz bei einfachen PWD
 - Simultaneous Authentication of Equals (SAE) auf Basis eines Pre Shared Key (PSK).
 - Brute Force Angriff aufwendiger (WPA2 400T/s)
- Individuelle Verschlüsselung
 - Perfect forward secrecy
 - Jede Verbindung verwendet eindeutigen eigenen Schlüssel.
 - In offenen Netzen eigener Schlüssel durch Diffie-Hellman, aber ohne Authentifizierung.

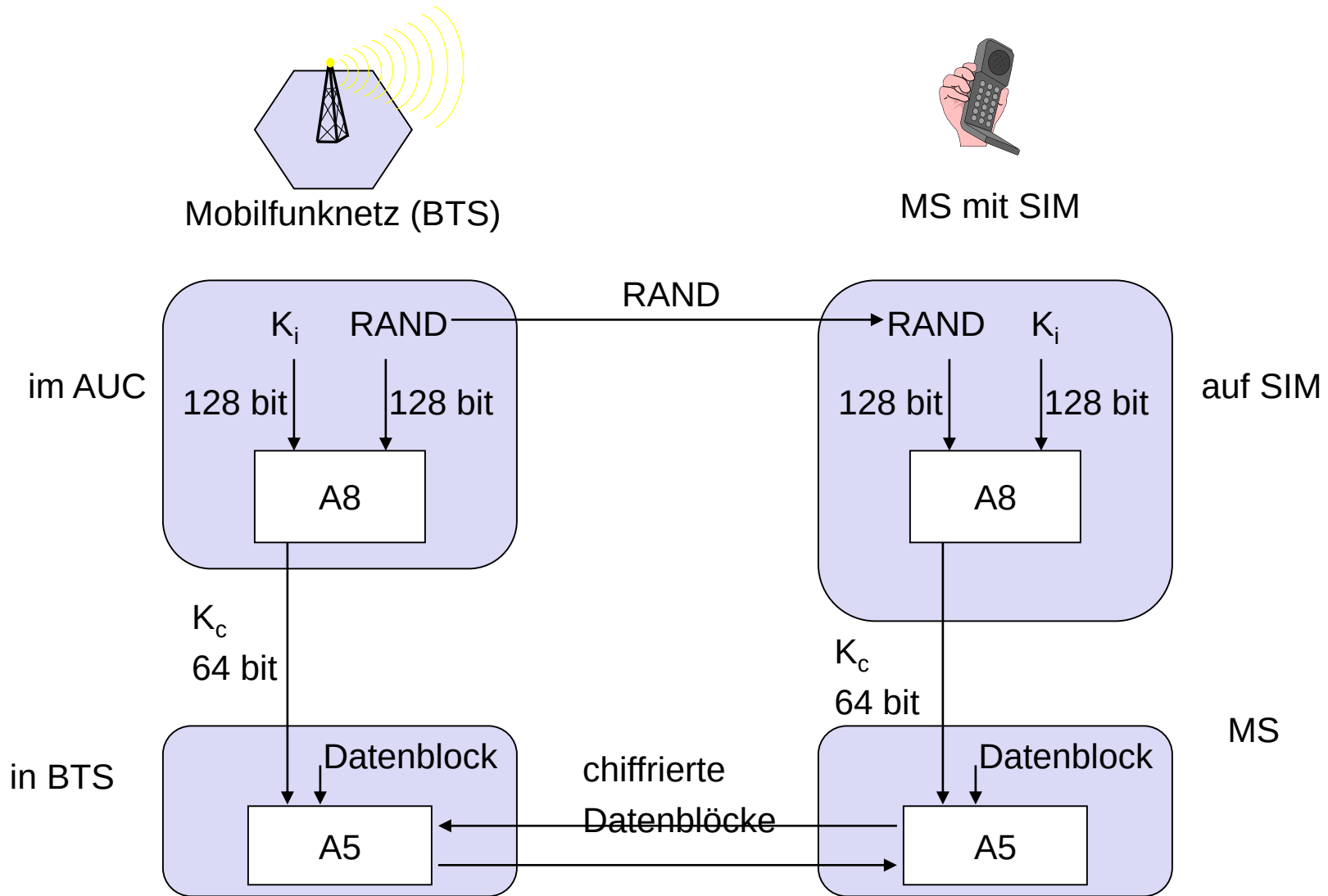
Netzwerksicherheit GSM Sicherheit

- Sicherheitsdienste in GSM
 - Zugangskontrolle / Authentifikation
 - Teilnehmer $\Leftrightarrow$ SIM (Subscriber Identity Module): Geheimnummer PIN
 - SIM $\Leftrightarrow$ Netzwerk: Challenge-Response-Verfahren
 - Vertraulichkeit
 - Sprache und Signalisierungsdaten werden nach erfolgreicher Authentifikation verschlüsselt übertragen.
 - Anonymität
 - Temporäre Teilnehmerkennung TMSI (Temporary Mobile Subscriber Identity)
 - Bei jedem Location Update (LUP) neu vergeben
 - Verschlüsselt übertragen
- 3 Algorithmen in GSM spezifiziert:
 - A3 zur Authentisierung („geheim“, Schnittstelle offengelegt)
 - A5 zur Verschlüsselung (standardisiert)
 - A8 zur Schlüsselberechnung („geheim“, Schnittstelle offengelegt)

Netzwerksicherheit GSM Ablauf Authentifikation

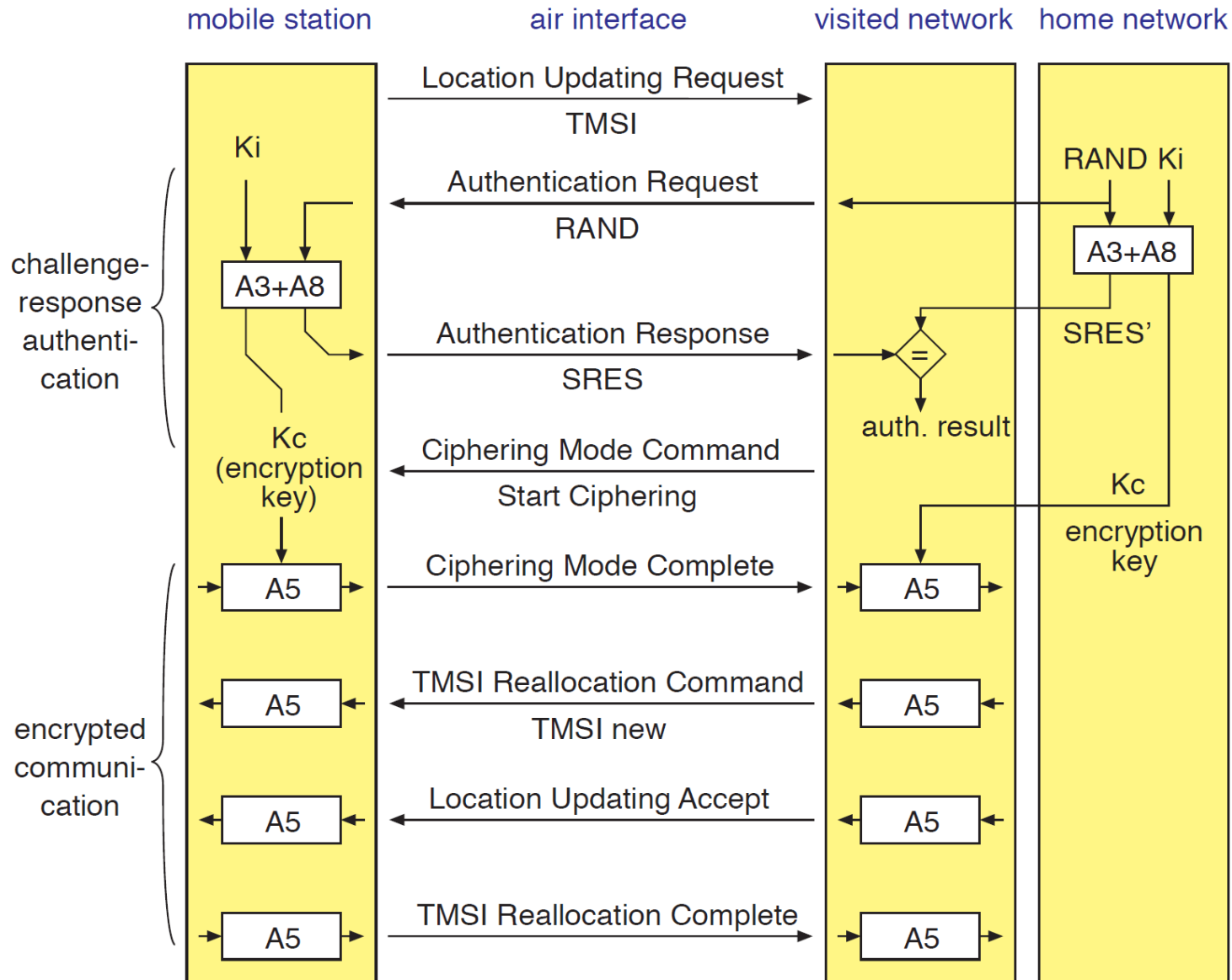


Netzwerksicherheit GSM Ablauf Verschlüsselung

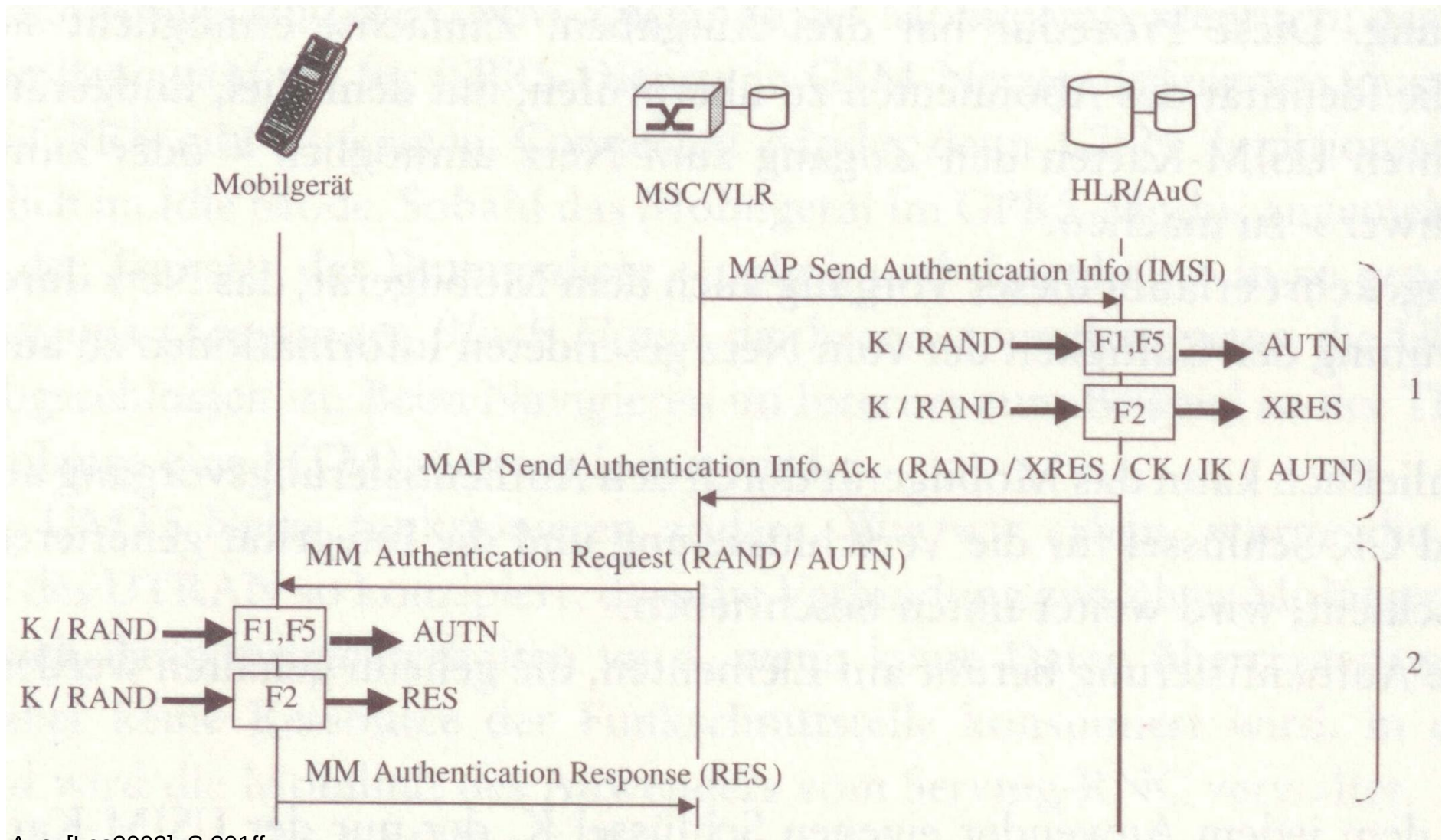


Aus [SCH200x], S. 156ff

Netzwerksicherheit GSM Gesamtablauf

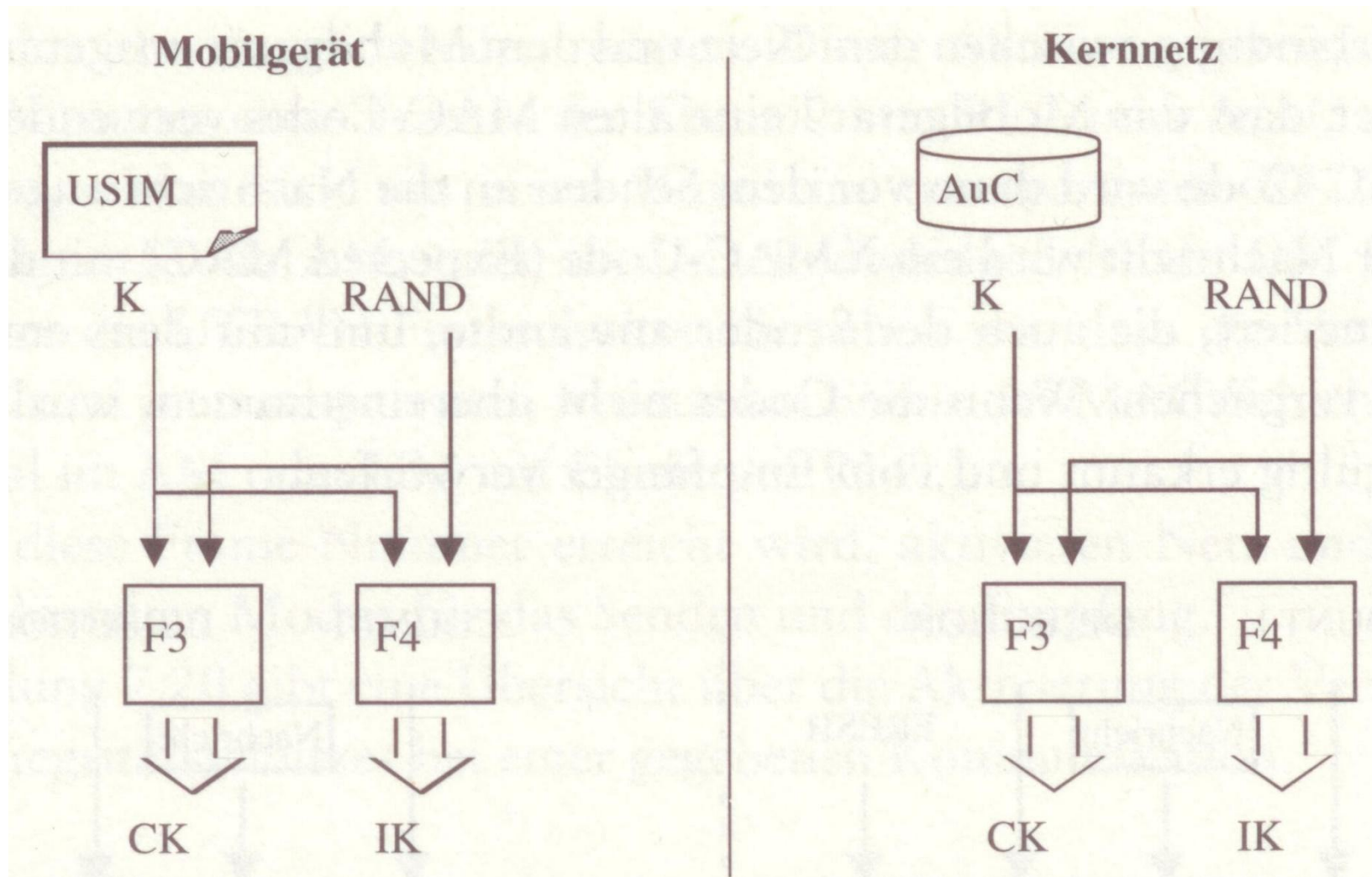


Netzwerksicherheit UMTS Authentisierung



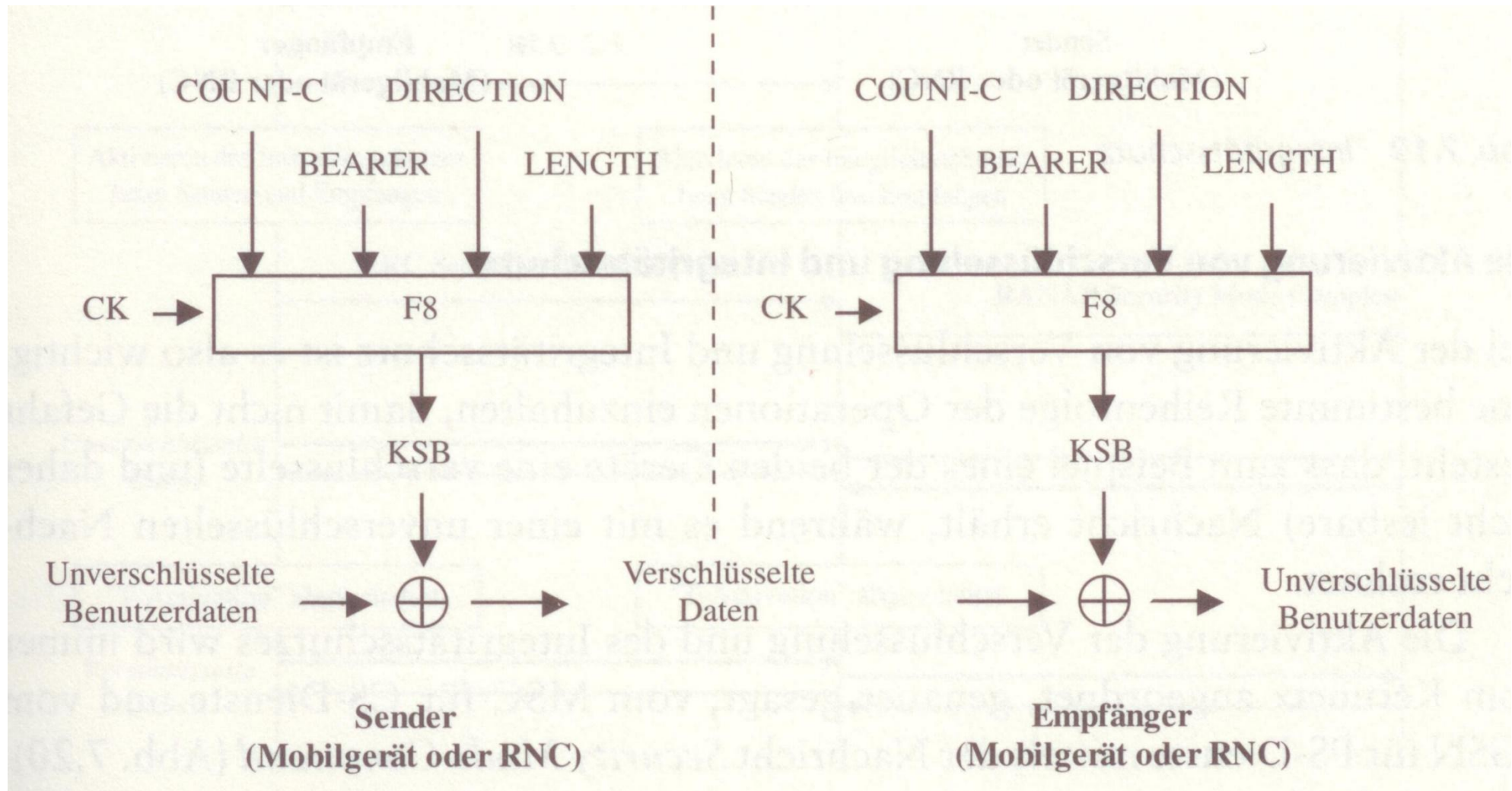
Aus: [Les2002], S.201ff

Netzwerksicherheit UMTS Schlüsselerzeugung



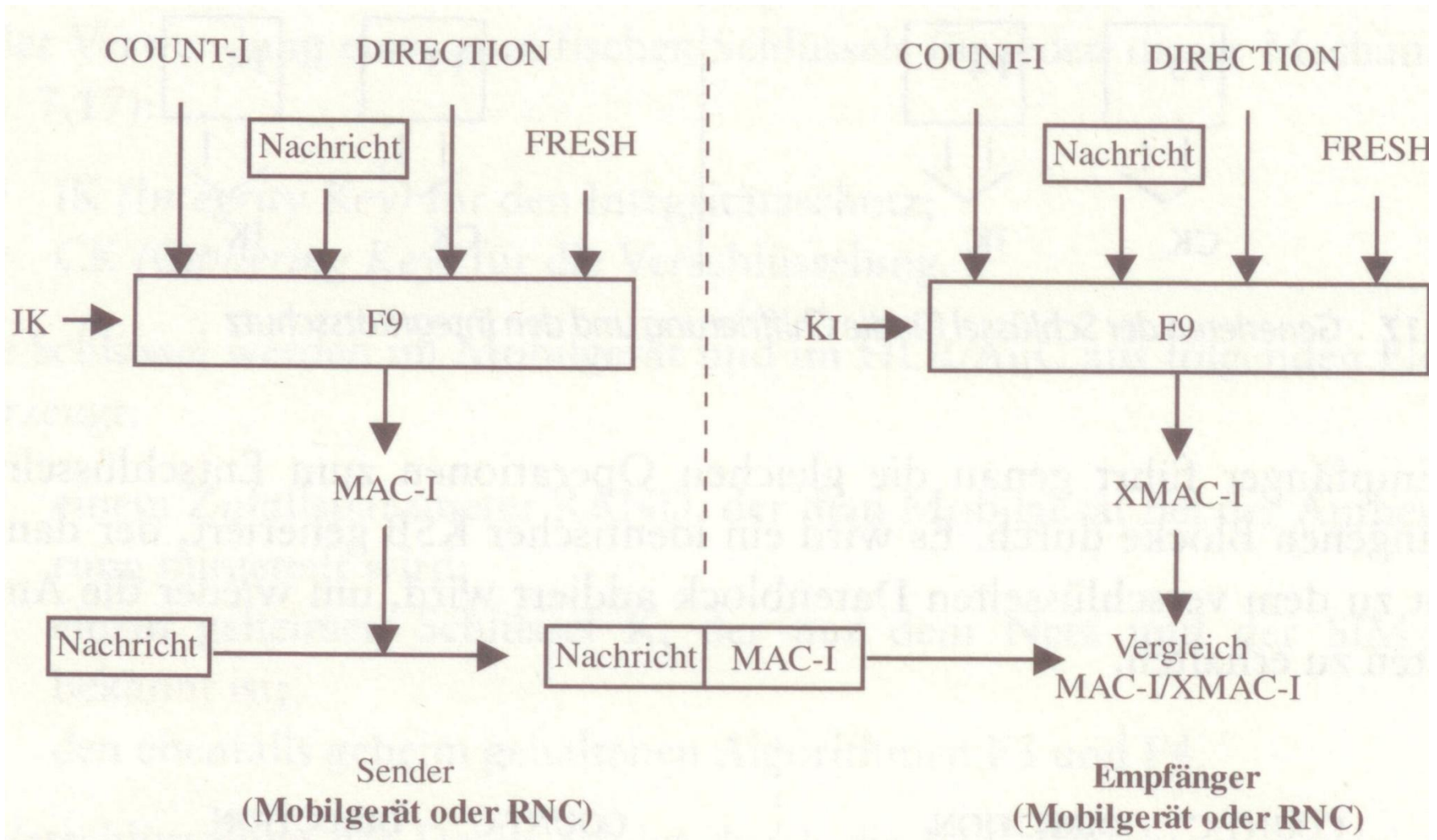
Aus: [Les2002]

Netzwerksicherheit UMTS Verschlüsselung



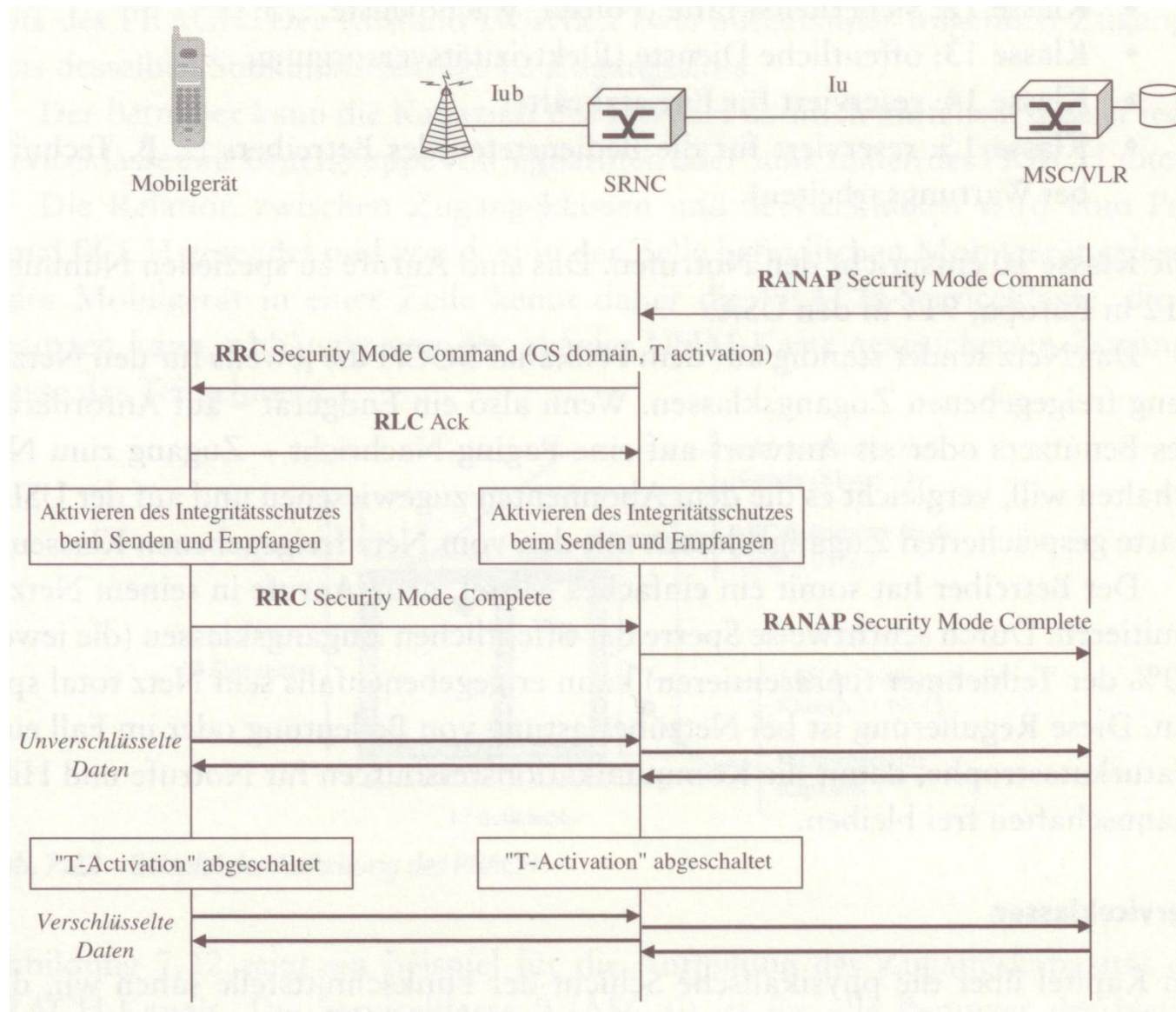
Aus: [Les2002]

Netzwerksicherheit UMTS Integrität



Aus: [Les2002]

Netzwerksicherheit UMTS Gesamtsystem



Aus: [Les2002]

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- 1995 als SSLv2 durch Netscape in Navigator 1.1 eingeführt
- 1996 Überarbeitung von SSLv2 zu SSLv3 (Netscape)
- ‚Quasi-Standard‘ für sichere TCP-Kommunikation
- 1999 Einführung von TLS (Transport Layer Security) v1.0
- IETF Industrie-Standard, eng an SSLv3 angelehnt, aber inkompatibel zu SSLv3 (u.a. HMAC statt MAC, unterschiedliche Berechnung der Schlüssel)
- Open-Source-Implementation unter <http://www.openssl.org>
- RFC 5246->8446 (TLS 1.2)
- RFC 2818 (HTTPS, SSL-basiertes HTTP)
- 21.3.2018 RFC 8446 (TLS 1.3)
- Aktuell ist alles vor TLS1.2 überholt....don't use.



Website-Identität

Website: de.wikipedia.org
Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.
Validiert von: DigiCert Inc
Gültig bis: Dienstag, 6. Oktober 2020

Zertifikat anzeigen

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 91 Mal
Speichert diese Website Daten auf meinem Computer? Ja, Cookies
Habe ich Passwörter für diese Website gespeichert? Nein

Cookies und Website-Daten löschen

Gespeicherte Passwörter anzeigen

Technische Details

Verbindung verschlüsselt (TLS_CHACHA20_POLY1305_SHA256, 256-Bit-Schlüssel, TLS 1.3)
Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.
Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

Hilfe



Allgemein



Medien



Berechtigungen



Sicherheit

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: Verein zur Foerderung eines Deutschen Forschungsnetzes e. V.

[Zertifikat anzeigen](#)

Gültig bis: Freitag, 24. April 2020

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 104 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies

[Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein

[Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384, 256-Bit-Schlüssel, TLS 1.2)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

[Hilfe](#)



Allgemein



Medien



Berechtigungen



Sicherheit

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: Verein zur Foerderung eines Deutschen Forschungsnetzes e. V.

[Zertifikat anzeigen](#)

Gültig bis: Mittwoch, 29. Juni 2022

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 30 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies und 119 KB Website-Daten

[Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein

[Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_AES_256_GCM_SHA384, 256-Bit-Schlüssel, TLS 1.3)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

[Hilfe](#)

Seiteninformationen - https://www.dhbw.de/startseite

Allgemein Medien Berechtigungen **Sicherheit**

Website-Identität

Website: www.dhbw.de

Besitzer: Diese Website stellt keine Informationen über den Besitzer zur Verfügung.

Validiert von: GEANT Vereiniging [Zertifikat anzeigen](#)

Datenschutz & Chronik

Habe ich diese Website früher schon einmal besucht? Ja, 480 Mal

Speichert diese Website Daten auf meinem Computer? Ja, Cookies und 783 KB Website-Daten [Cookies und Website-Daten löschen](#)

Habe ich Passwörter für diese Website gespeichert? Nein [Gespeicherte Passwörter anzeigen](#)

Technische Details

Verbindung verschlüsselt (TLS_AES_128_GCM_SHA256, 128-Bit-Schlüssel, TLS 1.3)

Die Seite, die Sie ansehen, wurde verschlüsselt, bevor sie über das Internet übermittelt wurde.

Verschlüsselung macht es für unberechtigte Personen schwierig, zwischen Computern übertragene Informationen anzusehen. Daher ist es unwahrscheinlich, dass jemand diese Seite gelesen hat, als sie über das Internet übertragen wurde.

Diese Website entspricht den Vorschriften für Zertifikat-Transparenz.

[Hilfe](#)

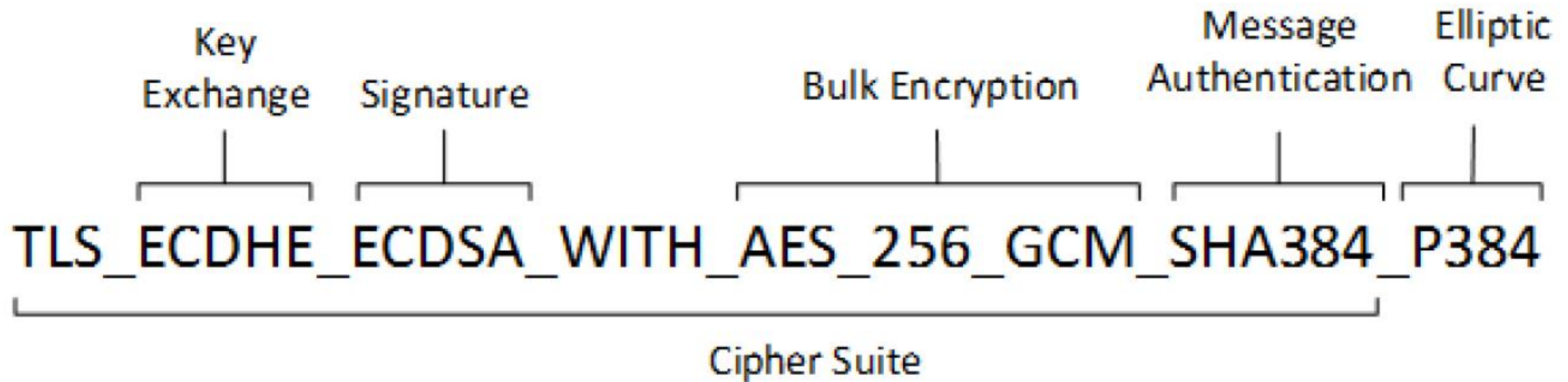
Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL/TLS: Konzepte und Schutzziele**
 - Basis: SSL/TLS setzt auf Schicht 4 (Transport) auf
 - Client-Server-Kommunikationsparadigma
- **Session:**
 - Aushandlung von zu verwendenden Krypto-Algorithmen und von einem gemeinsamen Master-Secret (MS),
 - Ggf. mehrere Verbindungen zugeordnet,
 - alle Verbindungen einer Session basieren auf dem MS.
- **Verbindung:** (entspricht einer TCP-Verbindung)
 - individuelle Keys pro Verbindung, abgeleitet aus MS
 - Verwendung der Algorithmen der zugeordneten Session
 - Verbindungsaufbau: vorhandene Session, oder neue

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- Bezug zu **Schutzzielen**
 - Sichere Client-Server-Kommunikation
- Authentifikation:
 - wechselseitig, einseitig (meist nur Server), anonym
 - Mechanismen: X509-Zertifikate, MACs (MD5, SHA-1,...)
- Integrität von Nachrichten
 - mit HMAC/MAC-Verfahren: SHA-1, MD5, SHA256
- Vertrauliche Datenübertragung
 - wählbare **Cipher-Suite**, (siehe nächste Folie)
 - symmetrische Verfahren
- Schlüsselaustausch:
 - Public-Key-Verfahren: RSA, DH

Windows 10 1709 TLS Suites Beispiele



- `TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384`
- ...
- `TLS_RSA_WITH_3DES_EDE_CBC_SHA`
- No `TLS_RSA_WITH_NULL_SHA256`

Windows 10 1709 TLS Suites Beispiele

- TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- TLS Version 1.2
- ECDHE – Ephemeral Elliptic Curve Diffie-Hellman key exchange
- ECDSA - Elliptic Curve Digital Signature Algorithm
- AES_256_GCM – Advanced Encryption Standard Galois/Counter Mode
- SHA384 – Secure Hash Algorithm
- Verwendete Elliptic Curve wird noch referenziert.

Windows TLS Cipher Suites

- <https://clienttest.ssllabs.com>

Testet die cipher suites, die Ihr Browser zulässt.

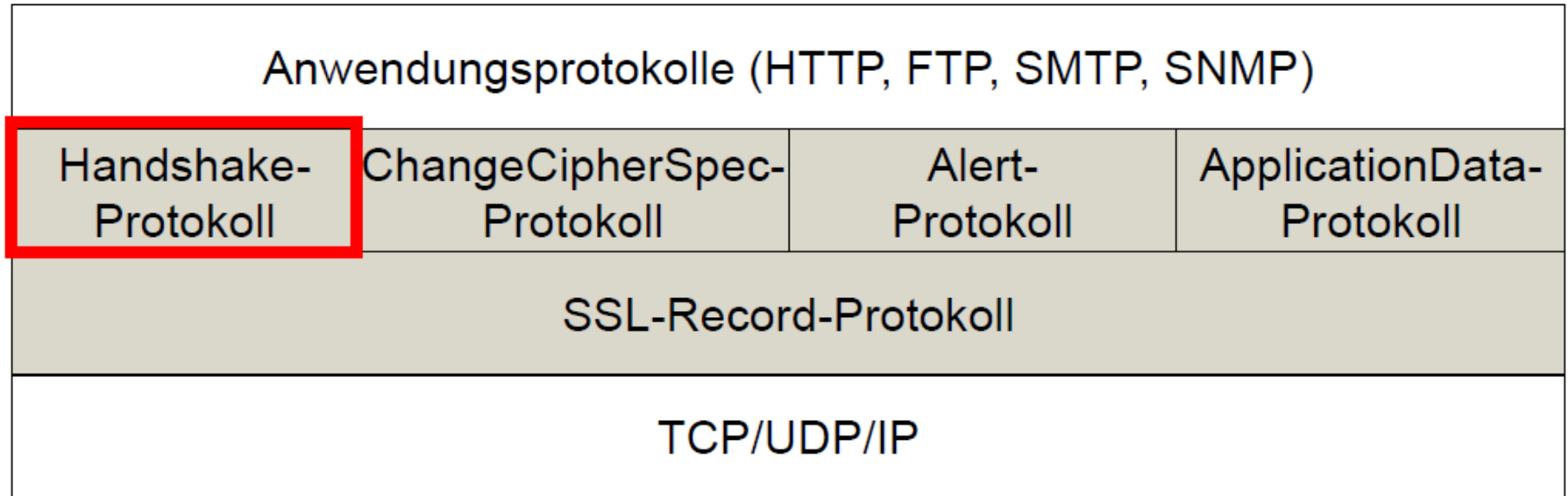
- Einstellung/Einschränkung der Cipher Suites

??

Firefox – about:config – einige Verfahren auswählen.

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- TLS Protokolle



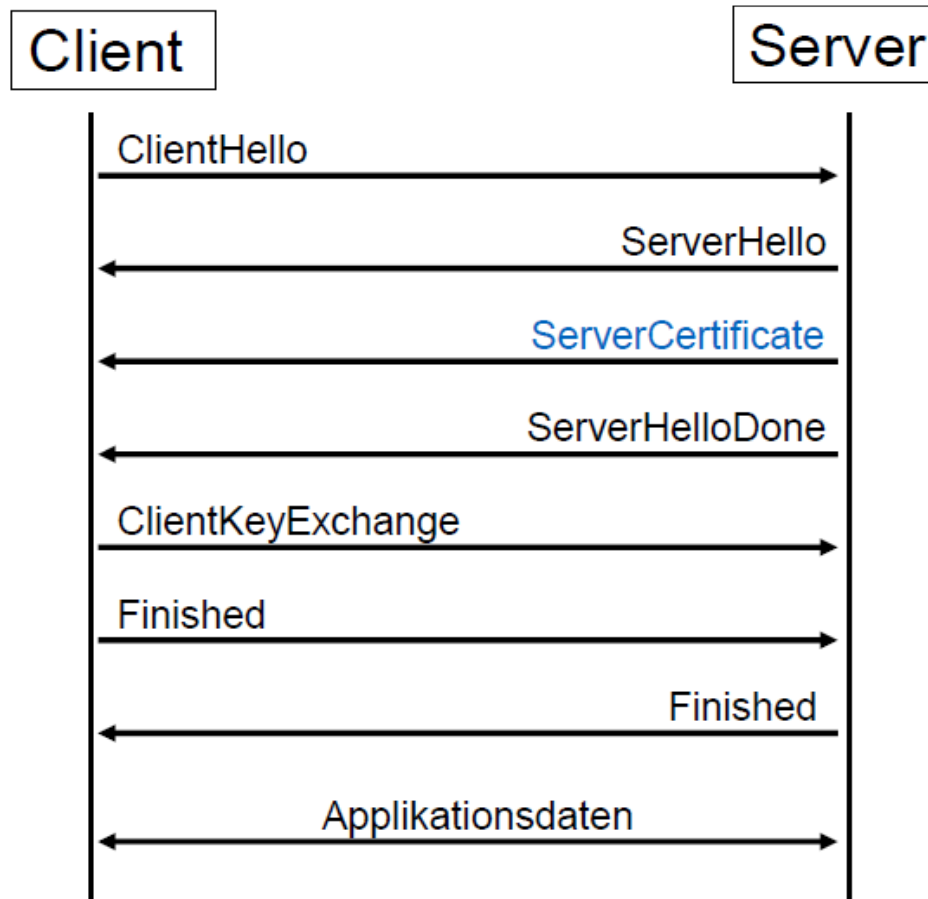
- **ChangeCipherSpec-Protokoll:** 1Byte
 - Zeigt die Verwendung der vereinbarten Verfahren an
- **Alert-Protokoll:** Fehlerbehandlung, (2 Byte)
 - Erstes Byte: Schwere (1=Warnung; 2=Abbruch)
 - Zweites Byte: Fehlertyp (z.B. MAC-Prüfung schlägt fehl)

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL/TLS-Handshake-Protokoll Aufgaben:**
 - Festlegen der zu verwendenden Krypto-(Suite)
 - Austausch von geheimer Basis-Information
 - unidirektionale Verbindung: mit unterschiedlichen Schlüsseln
 - Authentifikation mittels X509.v3-Zertifikaten
 - Verwaltung von Sitzungsinformationen:
Client/Server kann mehrere offene Sitzungen haben
- **Verschiedene Modi:**
 - Server authentifiziert, Client anonym (u.a. Web-Portale)
 - Server und Client authentifiziert (über Zertifikate)
 - Server und Client anonym

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL/TLS-Handshake-Protokoll**
 - **Server Auth, Client anon.**



ClientHello:

- Protokollversion
- Randomzahl R_c
- bekannte Verschlüsselungsmethoden
- bekannte Komprimierungsmethoden

ServerHello:

- Protokollversion
- Randomzahl R_s
- gewählte Verschlüsselungsmethoden
- gewählte Komprimierungsmethoden

ServerCertificate:

- Liste der Zertifikate der Zertifizierungskette
- Server-Public-Key, beim RSA-Verfahren

ClientKeyExchange:

- Pre-master Secret mit **Server-Public-Key verschlüsselt**

Finished (Server bzw. Clientkennung):

- Berechnen des Master-Secrets aus Pre-master und den Random-Werten R_c , R_s
- MD5-Hash-Wert mit Master-Secret über die bisher ausgetauschten Nachrichten
- SHA-Hash-Wert mit Master-Secret über die bisher ausgetauschten Nachrichten

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **SSL-Record-Protokoll**

- Aufteilung der Daten in Fragmente (und Kompression)
- MAC-Berechnung u. Verschlüsseln der Daten

- **Schlüsselerzeugung**

- **Schlüsselberechnung** aus Pre , R_C , R_S
- Berechnen des Master-Secrets durch Client u. Server
- Master-Secret = $MD5(Pre \mid SHA('A' \mid Pre \mid RC \mid RS)) \mid$
 $MD5(Pre \mid SHA('BB' \mid Pre \mid RC \mid RS)) \mid$
 $MD5(Pre \mid SHA('CCC' \mid Pre \mid RC \mid RS))$
- **Master-Secret:** $3 \cdot 128 \text{ Bit} = 384 \text{ Bit} = \mathbf{48 \text{ Byte}}$

- Aus Master-Secret geheime Session- und der MAC-Schlüssel durch mehrmalige Anwendung von MD5 und SHA-1 auf das Master-Secret ableiten

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- TLS unterstützt verschiedene Schlüsselaustauschverfahren
RSA ist eine Möglichkeit
- Alternative: Nutzung des DH-Verfahrens:
 - idR in Kombination mit DSS, wg. Man-in-the-Middle
 - Server generiert temporären DH-Public_Key: KDH
 - Server signiert KDH mit seinem DSS-Signaturschlüssel
 - Server erhält die DH-Parameter des Clients
 - Server und Client berechnen den gemeinsamen DH-Schlüssel KSC
 - der Schlüssel KSC ist dann das Pre-Master-Secret
- Anonymes DH: nur Austausch von DH-Parametern,
 - anfällig gegen Man-in-the-Middle

Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **Client-Authentifikation: optional**
 - Server initiiert die Client-Authentifizierung, d.h. er entscheidet, ob Client-Authentifizierung notwendig ist
 - Server sendet Certificate_Request-Nachricht
 - Client signiert die Daten aus dem Request:
RSA(Request_Data, Private_KeyClient)
 - Client sendet Client-Zertifikat und signierten Request
 - Server prüft die Signatur
- **Session:** das Handshake-Protokoll unterstützt:
 - erneute Verwendung von Session-IDs, z.B. Web
 - Aushandeln neuer Ciphersuites während einer Session
 - Re-Keying Verbindung: Handshake mit frischen Nonces

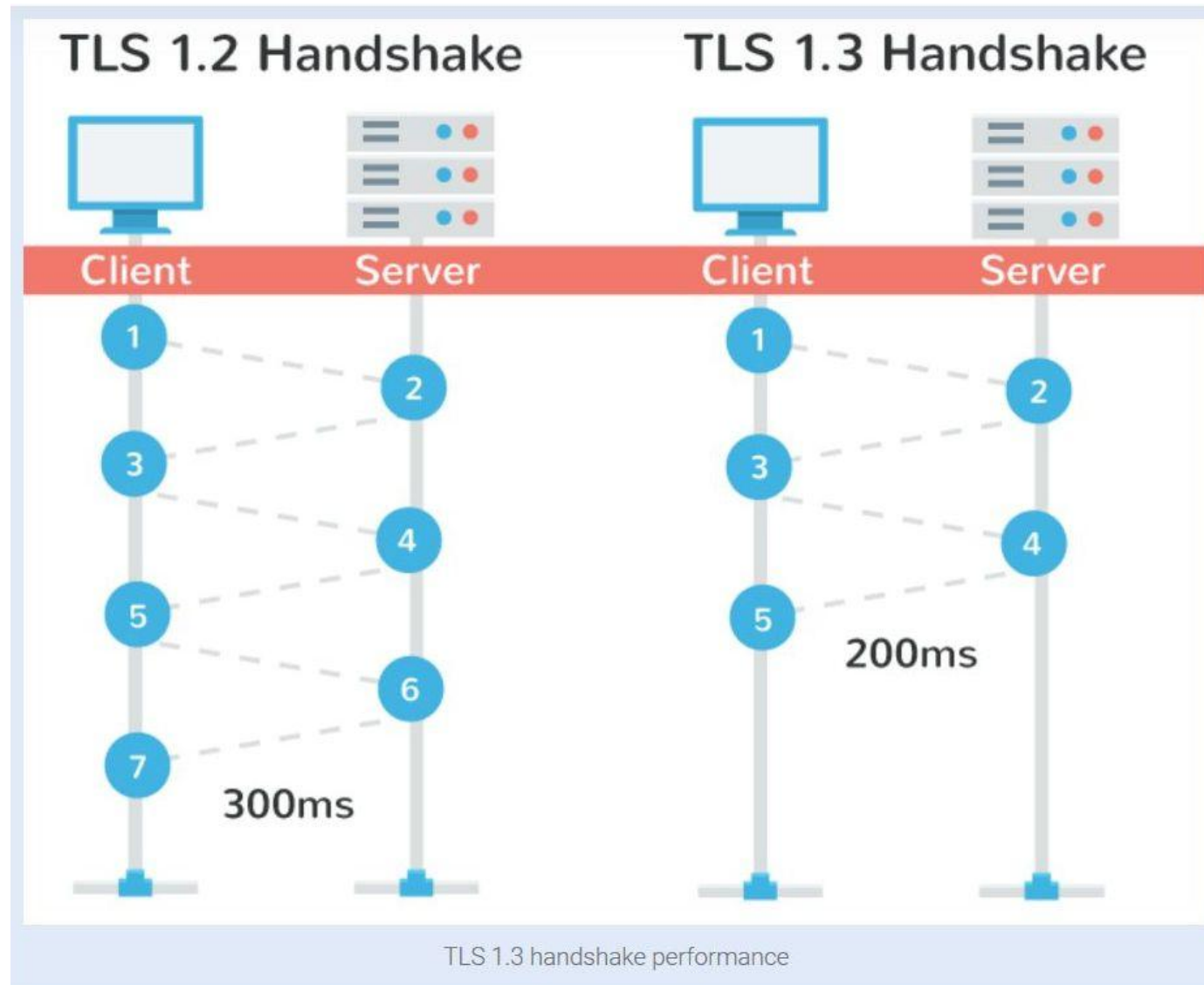
Netzwerksicherheit Techniken Verschlüsseln TLS (SSL)

- **Probleme, Grenzen von SSL**
 - keine Verbindlichkeit: keine Signaturen
 - Probleme beim Zusammenwirken mit Firewalls möglich
 - Vielzahl von vorkonfigurierten CAs: Vertrauen?
 - Werden Zertifikate geprüft? Warnungen ignoriert?
 - Stimmt Name im Zertifikat mit URL überein?
- Sichere Speicherung Master-Secrets, der Session-Keys?
- Hacker-Angriffe auf CAs (u.a. DigiNotar 2011):
- Haftung für CA-Betreiber? (EU-Regelung in Vorbereitung)
- Häufig fehlende Zertifikatprüfung bei non-Browse-Anwendungen (Cloud-Storage, PayPal Payment etc) durch fehlerhafte Nutzung von SSL-Libraries:
 - anfällig gegen MitM Angriffe

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3

- Am 21.3.2018 verabschiedet (draft-ietf-tls-tls13-28).
- Handshake schneller (Schritte eliminiert)
- Schneller durch moderne Verschlüsselungsprotokolle (forced use)
- “zero round trip.” (0-RTT) – bekannte Verbindung fortsetzen
- Unsichere Methoden ausgeschlossen: SHA-1, RC4, DES, 3DES, AES-CBC, MD5..., Export-Verschlüsselung
- Zeitnah Implementiert in Chrome und Firefox
- <https://kinsta.com/blog/tls-1-3/>

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3



<https://kinsta.com/blog/tls-1-3/>

Netzwerksicherheit Techniken Verschlüsseln TLS 1.3

- Cipher Suites eng begrenzt.
- Record Protection und Hash Algorithmus festgelegt.
- TLS_AES_128_GCM_SHA256
- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_CCM_SHA256
- TLS_AES_128_CCM_8_SHA256

Netzwerksicherheit Techniken Verschlüsseln IPsec

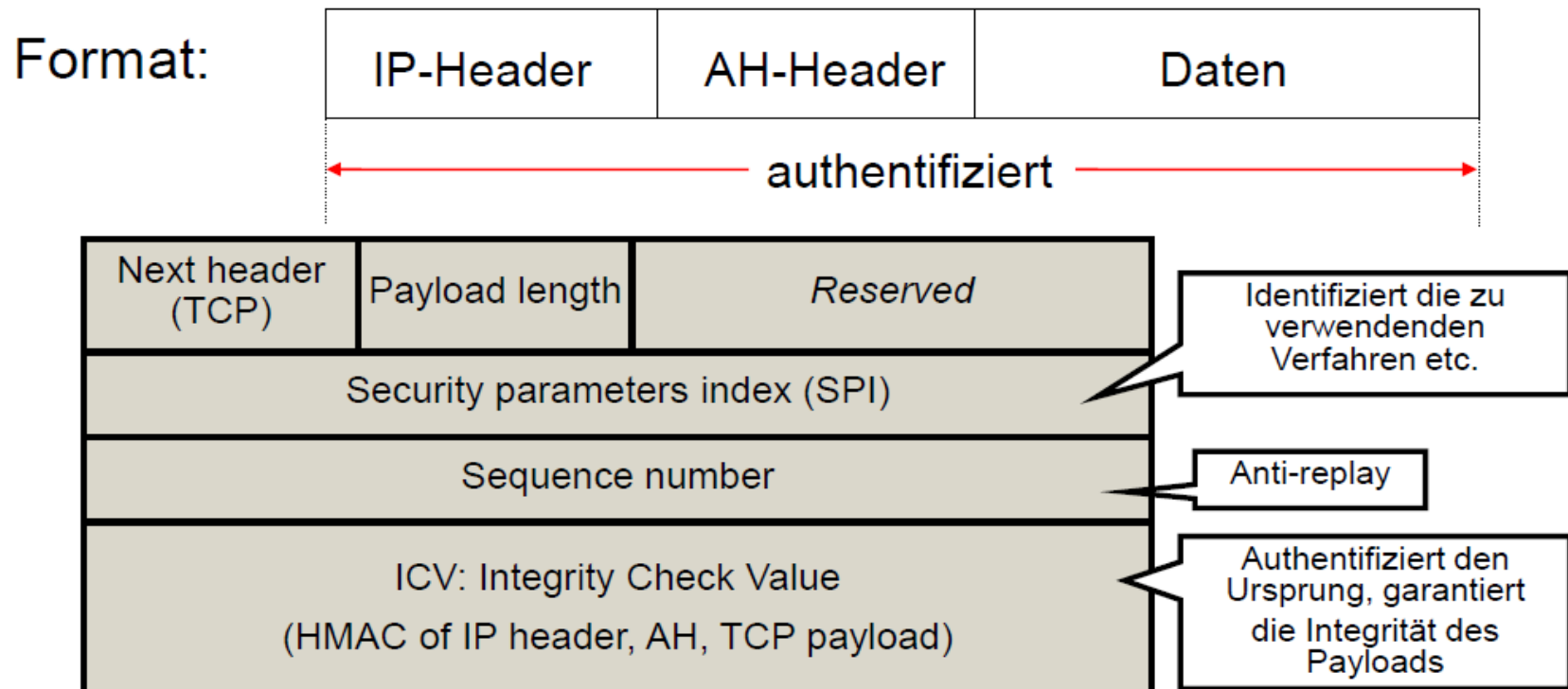
- **IPsec - Standard für Schicht 3**
- **Sicherheitsarchitektur** für Internetprotokolle, seit 1995 verschiedene RFCs: 4302 (AH), 4303 (ESP), 4306 (IKE) ...
 - optionaler Einsatz im IPv4 und **optional** für IPv6 (RFC8504)
 - 2 Modi: Transport und Tunnel-Modus (insbes. bei VPN)
- **Ziel: Gewährleistung von Schutzzielen auf IP-Ebene**
 - Authentizität des Datenursprungs
 - Vertrauliche Datenübertragung (Payload)
 - Integrität u. Schutz vor Replay-Attacken
 - Schlüsselmanagement: Erneuerung, Austausch

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Protokolle:**
 - AH und ESP: Integrität, Vertraulichkeit angewandt auf einzelne IP-Pakete
 - IKE: Aushandeln der Verfahren und Schlüssel
- **Regelwerk (Policy):** muss konfiguriert werden
 - welche Pakete, von wem, zu wem, mit welchen Verfahren
 - Security-Policy-Database (SPD) (pro IPsec-Rechner)
- **Speicherung der Sicherheitsparameter:**
 - Security-Association (SA): Verfahren, Schlüssel,
 - Verfahren, Schlüssel pro ‚Verbindung‘ : Zustand in IP!
 - Inbound, Outbound-Datenbanken

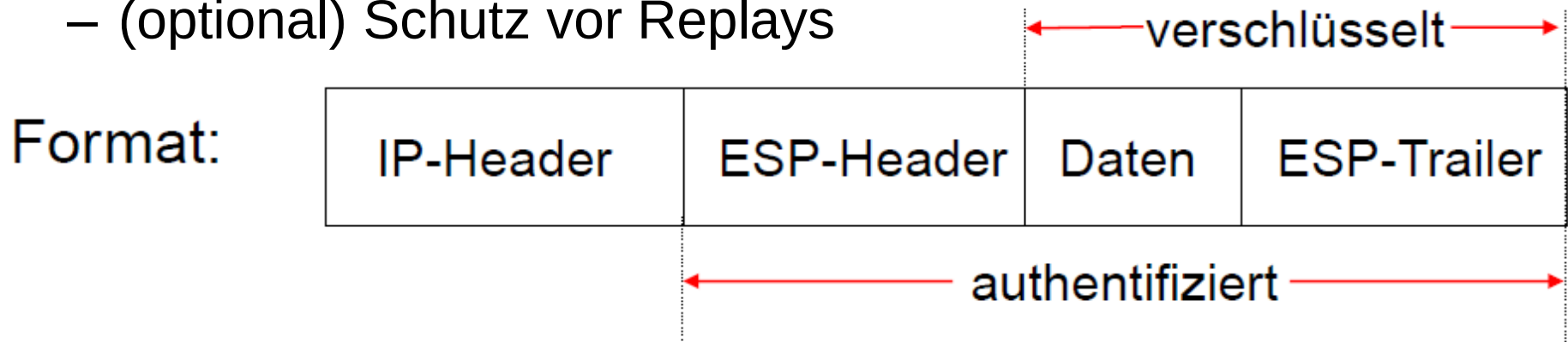
Netzwerksicherheit Techniken Verschlüsseln IPsec

- IP-Protokollerweiterungen: AH und ESP
- Authentication-Header-Protokoll (AH) RFC 4302
 - Authentizität, Integrität des Datenursprung u. Payloads
 - Verhinderung von Replay-Attacken über Sequenznr



Netzwerksicherheit Techniken Verschlüsseln IPsec

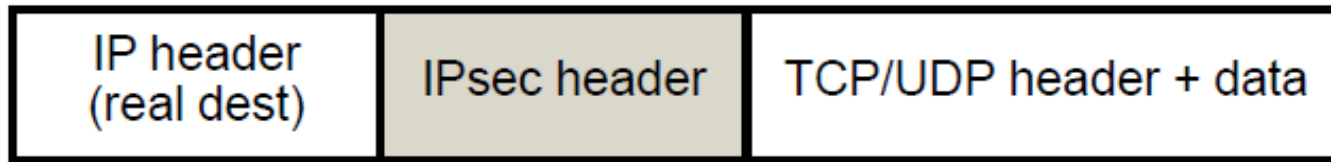
- **Encapsulating Security-Payload (ESP) RFC 4303**
 - Vertraulichkeit der Daten des IP-Datenpakets, Symmetrische Blockchiffre, NULL-Algorithmus zulässig
 - Authentisierung des Payloads mittels HMAC
 - (optional) Schutz vor Replays



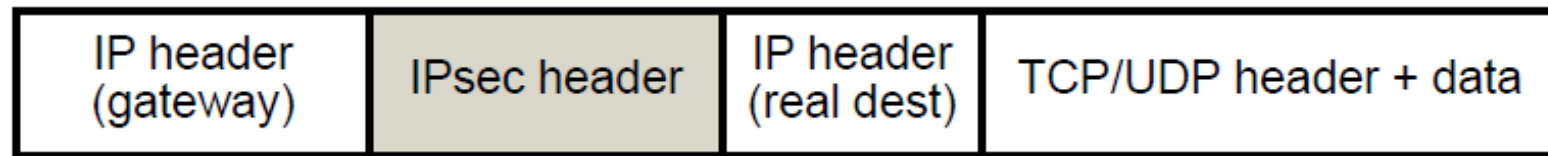
- **Durch IPsec wird ein IP-Paket verändert:**
 - zusätzliche Header
 - Verschlüsseln und/oder Hashen der Daten (Payload)

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **IPsec – 2 Modi: Transport- und Tunnel-Modus**
- **Transport-Modus:** Absichern des Payloads,



- **Tunnel-Modus:** Einkapseln sowohl des IP-Headers als auch des Payloads in IPsec-Paket



- **Geschachtelte Tunnels** sind möglich, z.B. für sichere Verbindung über eine Firewall:
 - Äußerer Tunnel durch das Internet zur Firewall
 - innerer Tunnel, Verb. von Firewall zum Server sichern

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Security-Association-Datenstruktur (SA)**
 - SAs werden in den SA-DBs von A bzw. B verwaltet
 - SA enthält alle benötigten Informationen für IPsec-Verbindung zwischen zwei Rechnern A und B
 - SAs haben nur unidirektionale Gültigkeit
 - für jedes Protokoll (AH/ESP) eigene SA nötig
 - SAs vorab idR über IKE ausgehandelt und erstellt
 - SA wird beim erstmaligen Verbindungsaufbau angelegt
- **SPI:**
 - jedes IPsec Paket enthält einen Index (SPI), verweist auf einen SA-Eintrag in der SA-DB des Empf.
 - diese SA enthält die notwendigen Verarb.-info.

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Info in SA**

- IP-Adresse des Empfängers
- AH-Informationen:
 - Algorithmus, Schlüssel, Schlüssellebenszeit
- ESP-Informationen:
 - Algorithmen, Schlüssel, Initialwerte, Lebenszeiten, ...
- Lebenszeit der SA: Zeitintervall oder Bytecounter, nach dem die SA erneuert oder terminiert werden muss und Angabe, welcher dieser Aktionen auszuführen ist
- Sequenzzähler (ab IKEv2 64 Bit, vorher 32 Bit) AH, ESP
- Modus: Transport oder Tunnel
- Anti-Replay-Window, einkommende Replays erkennen
- Security-Level (z.B. für Multi-level sichere Systeme)

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Security-Policy-Database:** Pro IPsec-Rechner eine SPD:
 - SPD legt Regeln für den Umgang mit IP-Paketen fest
 - individuelle Regeln für eingehende (inbound) und
 - für ausgehende Pakete (outbound)
 - jede Regel wird über einen Selektor spezifiziert:
 - Selektor ist für ein IP-Paket anzuwenden, wenn die Einträge des IP Pakets mit Selektorfeldern matchen
 - ist Selektor anwendbar (match), dann enthält die SPD die mit dem IP-Paket durchzuführende Aktion

From	To	Protocol	Port	Policy
1.1.1.1	2.2.2.2	TCP	80	Transport ESP with 3DES

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Selektoren**, die einen SPD-Eintrag bestimmen:
 - die IP-Adresse, Adressbereiche oder Wildcard des Empfängers bzw. des Senders
 - Sender-, Empfänger-Ports, Liste von Ports oder Wildc.
 - Name: z.B. DNS-Name, X.500 Distinguished Name,
- **Unterschied** zwischen outbound/inbound Paketen:
 - bei ausgehenden Paketen werden beim Anwenden der Regel die erforderlichen SAs (AH, ESP) etabliert (IKE)
 - inbound Pakete: verwerfen, falls keine SA vorhanden
- **Aktionen**:
 - bypass: direktes Weiterleiten des Pakets
 - apply: IPsec muss angewandt werden, Verweis auf SA
 - discard: das Paket muss vernichtet werden

Netzwerksicherheit Techniken Verschlüsseln IPsec

- **Ablauf** beim Versand eines IPsec-Pakets von A nach B
 - A sucht SA für Verbindung mit B in SA-Datenbank von A
 - A verwendet die dort angegebenen Informationen: Verschlüsselung, Hashen, MAC berechnen, ...
 - Aus SA-Eintrag: SPI zum Empfangen des Pakets in SA_DB_B
 - A trägt diese SPI in IPsec-Header ein

SPD von A

From	To	Protocol	Port	Policy
1.1.1.1	2.2.2.2	TCP	80	Transport ESP with 3DES

SA-DB von A

From	To	Protocol	SPI	SA-Eintrag
1.1.1.1	2.2.2.2	ESP	10	3DES key

Netzwerksicherheit Techniken Verschlüsseln IPsec IKE

- **IKEv2** (Internet-Key-Exchange-Protokoll Version 2)
IKE ist kein integraler Bestandteil von IPsec
- **Schlüsselmanagement:**
 - Aushandeln bzw. Verteilen von Schlüsseln
- **Überblick**
 - IKEv2-Protokoll-Spezifikation: siehe RFC 5996
 - IKE ist Bestandteil von ISAKMP (Internet Security Association and Key Management Protocol)
 - IKE ist eine Ausprägung des allgemeineren Oakley-Protokolls (sehr viele Optionen, Parameter, komplex!)
 - IKE ist generisch, kann auch für andere Protokolle als IPsec verwendet werden, z.B. RIP

Netzwerksicherheit Techniken Verschlüsseln IPsec

Fazit

- Konfigurieren von IPsec-Policies ist sehr komplex
 - fehleranfällig: viele Optionen, viele Freiheitsgrade
 - ggf. Nutzung schwacher Modi, unsichere Auswahl
- Konfigurierungsvarianten führen zu Interoperabilitätsproblemen
- IKE-Pakete werden über UDP übertragen: unzuverlässig und wird von einigen Firewalls blockiert (ggf. kein Aushandeln mögl.)
- Interworking von IPsec und Firewalls ist problematisch
- Mechanismen bereits in Win XP (versteckt) vorgesehen.
- Bei korrekter Nutzung hoher Sicherheitsgrad erreichbar

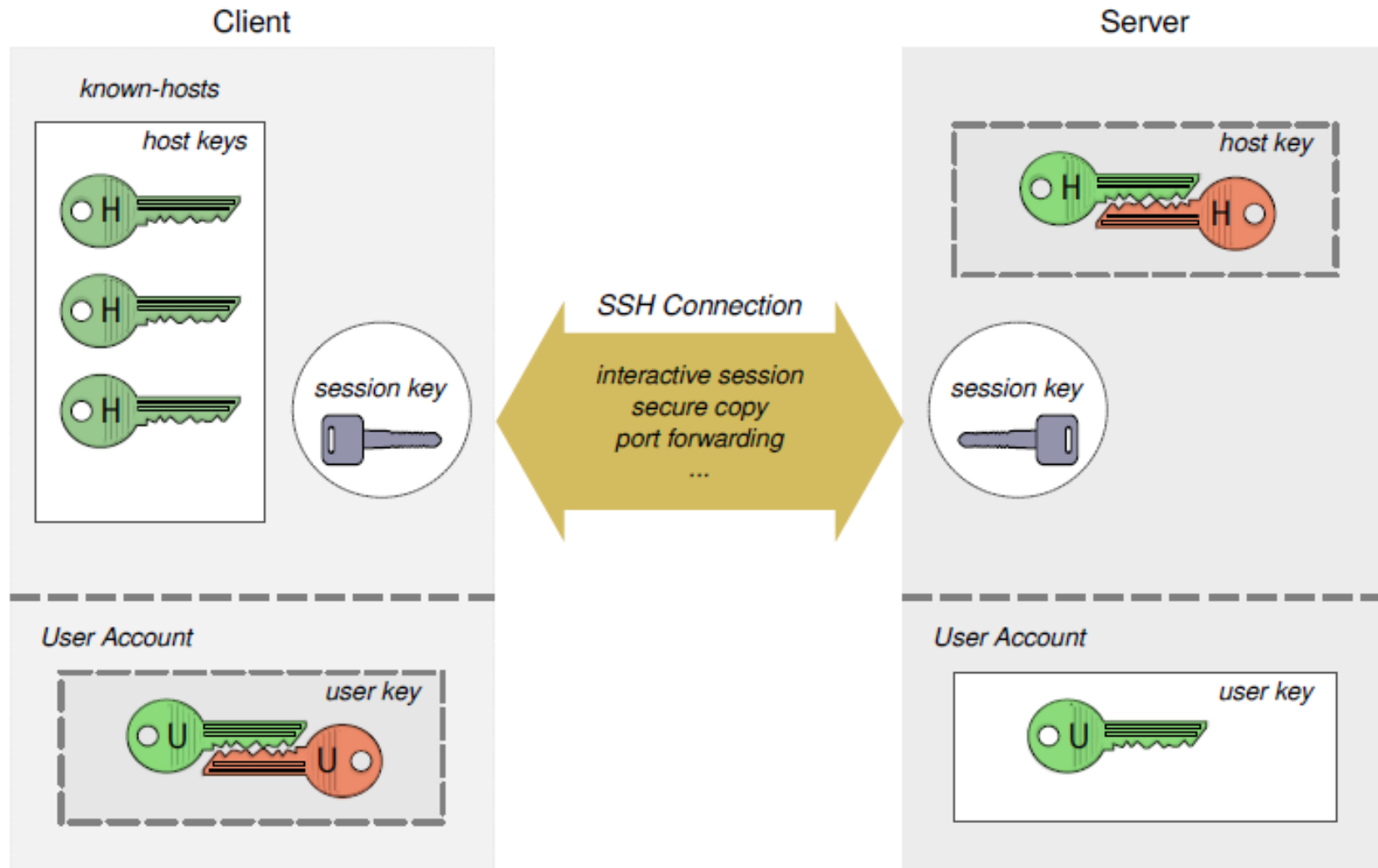
Netzwerksicherheit Techniken Verschlüsseln

- Vergleich IPsec und TLS
 - Unterschiede
 - Vorteile, Nachteile

Netzwerksicherheit Techniken Verschlüsseln SSH2

- Sicherheit in der Anwendungsschicht
 - Anwendungen
 - Sicheres remote login
 - Sichere Dienste (ftp, copy,...)
 - Sicheres port forwarding
 - Vorteile
 - Mehrere Authentifizierungsmethoden (Server: Zertifikat, Client: Zertifikat oder Kennwort)
 - Firewalls können vermieden werden.
 - Starke Verschlüsselung (z.B. AES)
 - Nachteile
 - Punkt-zu-Punkt

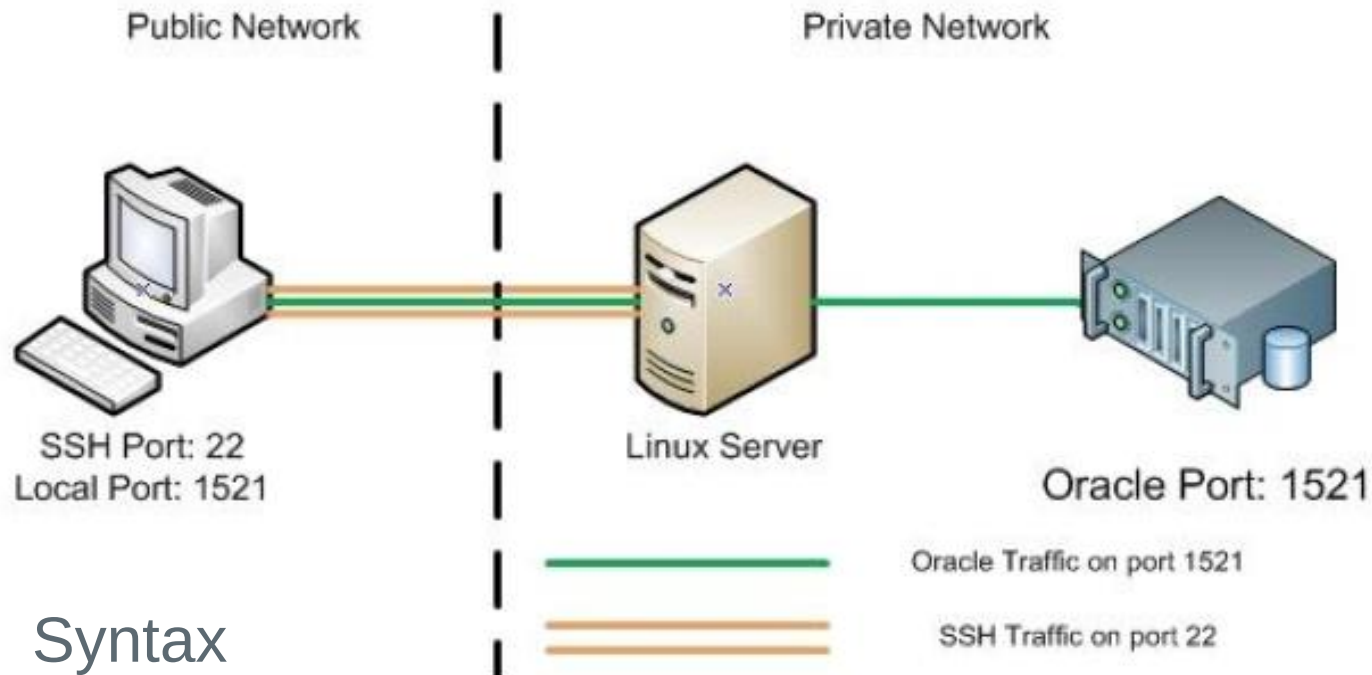
Netzwerksicherheit Techniken SSH Architektur



Netzwerksicherheit Techniken SSH Funktionalität

- Remote Login
 - Username/Password
 - Public Key
- Remote Command Execution
- Remote Copying (rcp)
- Secure ftp Service (sftp)
- Remote Synchronisation (rsync)
- Port Forwarding, Port Tunnel
- Secure File System Mount (sshfs)

Netzwerksicherheit Techniken SSH Port Forwarding

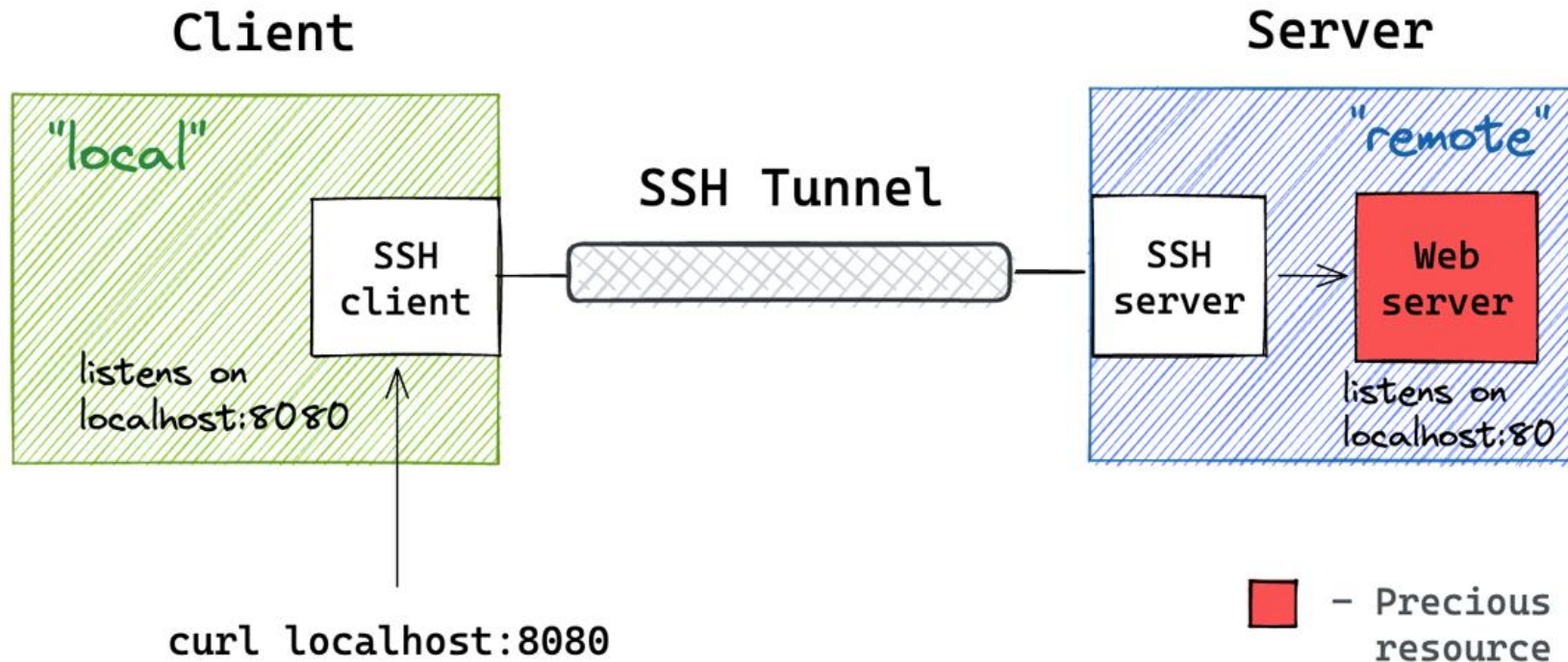


- Syntax
 - Local forwarding
 - `Ssh -L <lport>:<rhost>:<rport> user@host`
 - Remote forwarding
 - `Ssh -R <port>:<lhost>:<lport> user@host`

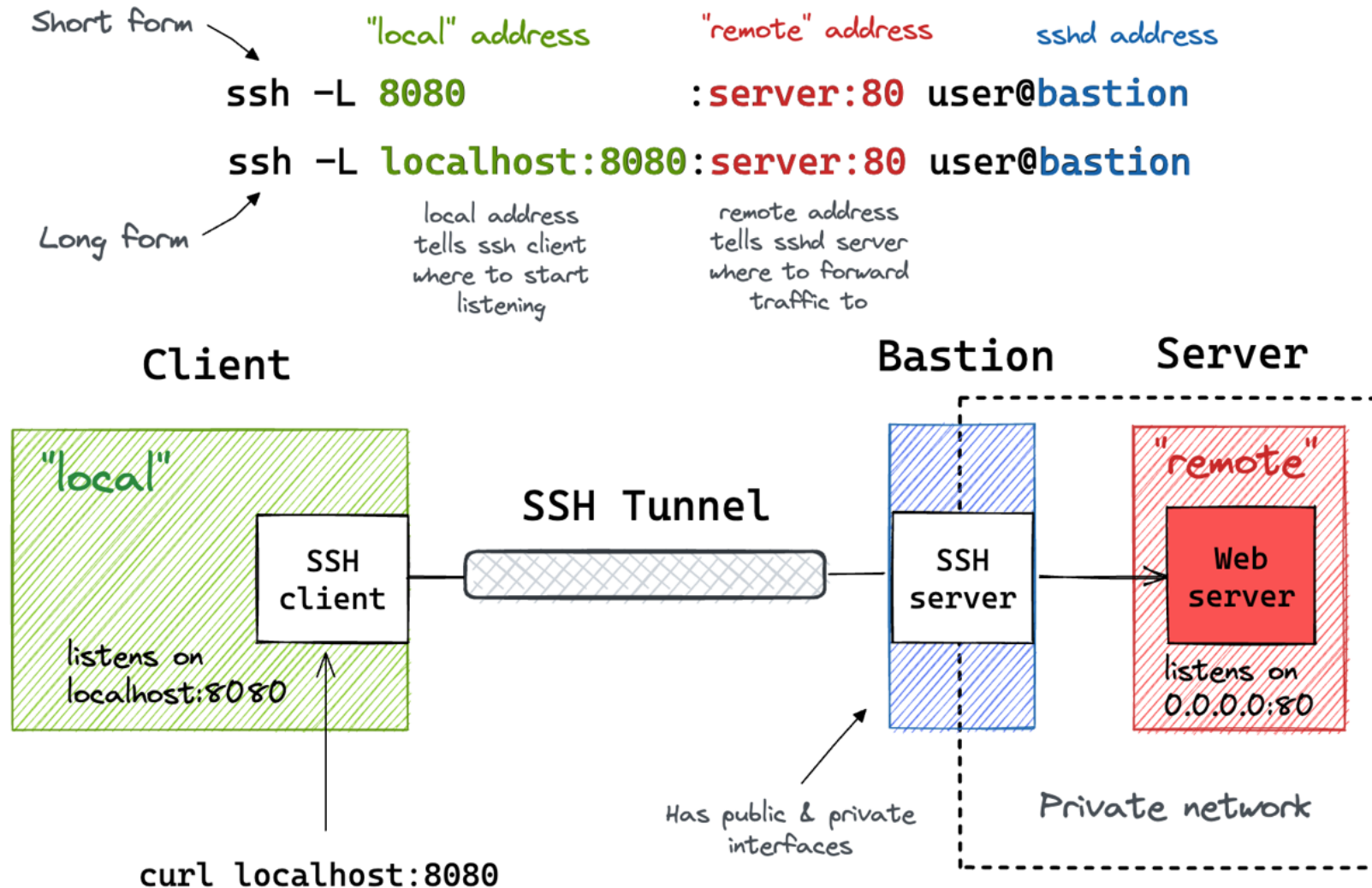
SSH Local Forwarding

Short form → `ssh -L 8080` "local" address "remote" address sshd address
`:localhost:80 user@server`

Long form → `ssh -L localhost:8080:localhost:80 user@server`
local address tells ssh client where to start listening
remote address tells sshd server where to forward traffic to



SSH Local Forwarding



SSH Remote Forwarding

"remote" address

"local" address

sshd address

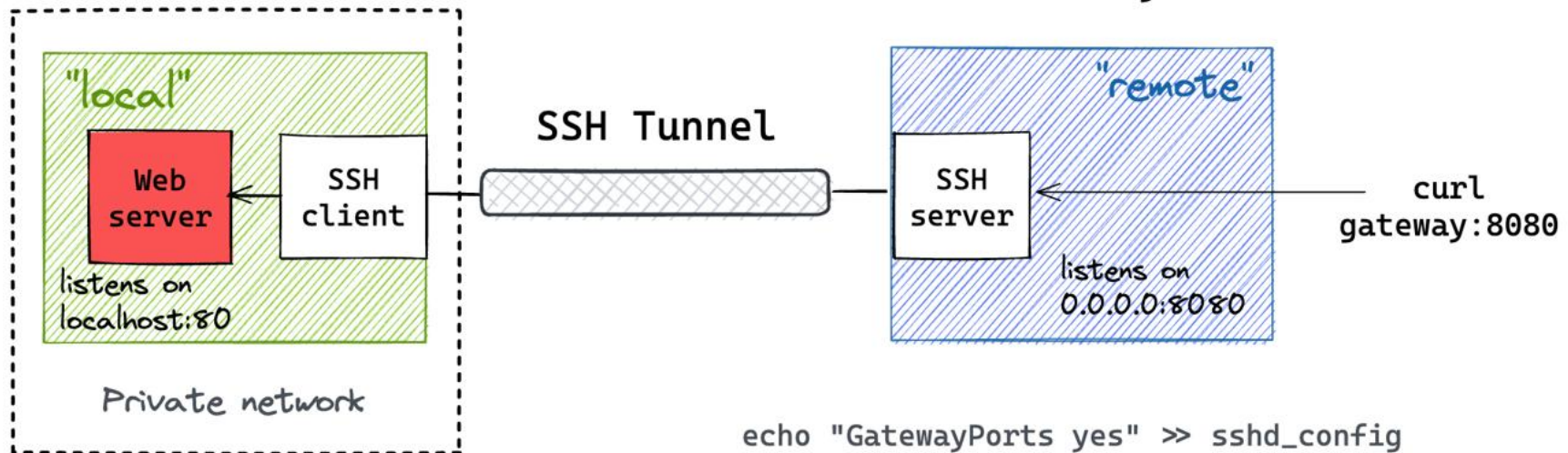
```
ssh -R 0.0.0.0:8080:localhost:80 user@gateway
```

remote address
tells sshd server
where to start
listening

local address
tells ssh client
where to forward
traffic to

Client

Gateway



```
echo "GatewayPorts yes" >> sshd_config
```

 - Precious resource

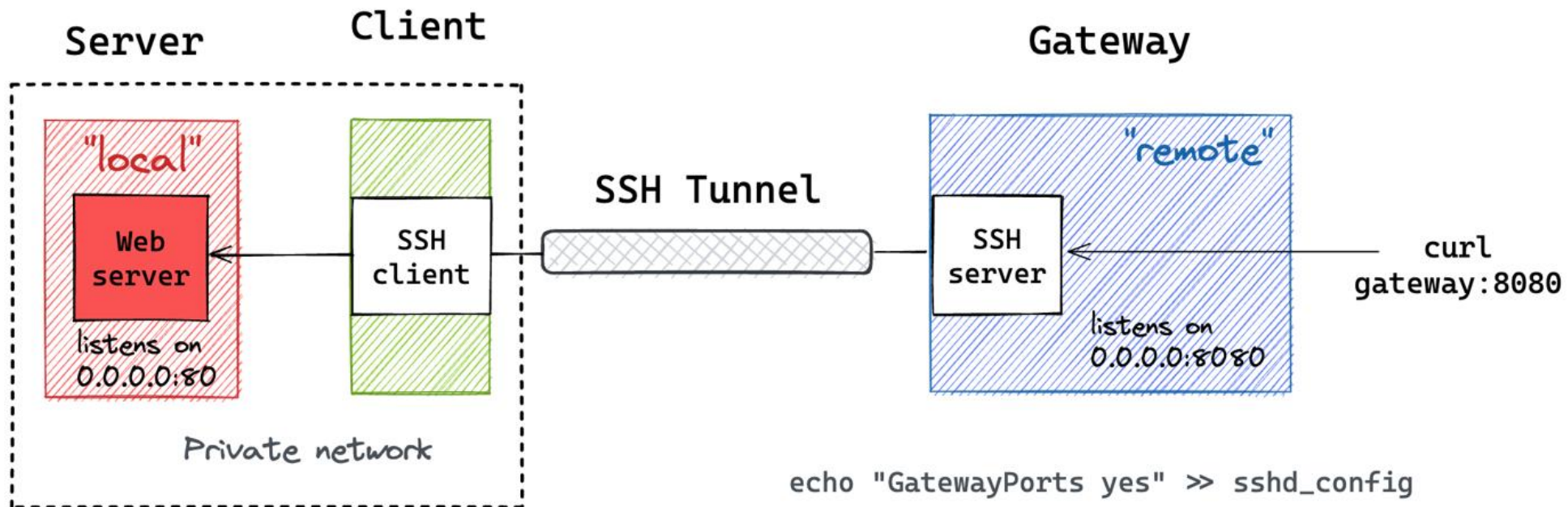
SSH Remote Forwarding

"remote" address "local" address sshd address

```
ssh -R 0.0.0.0:8080:server:80 user@gateway
```

remote address
tells sshd server
where to start
listening

local address
tells ssh client
where to forward
traffic to

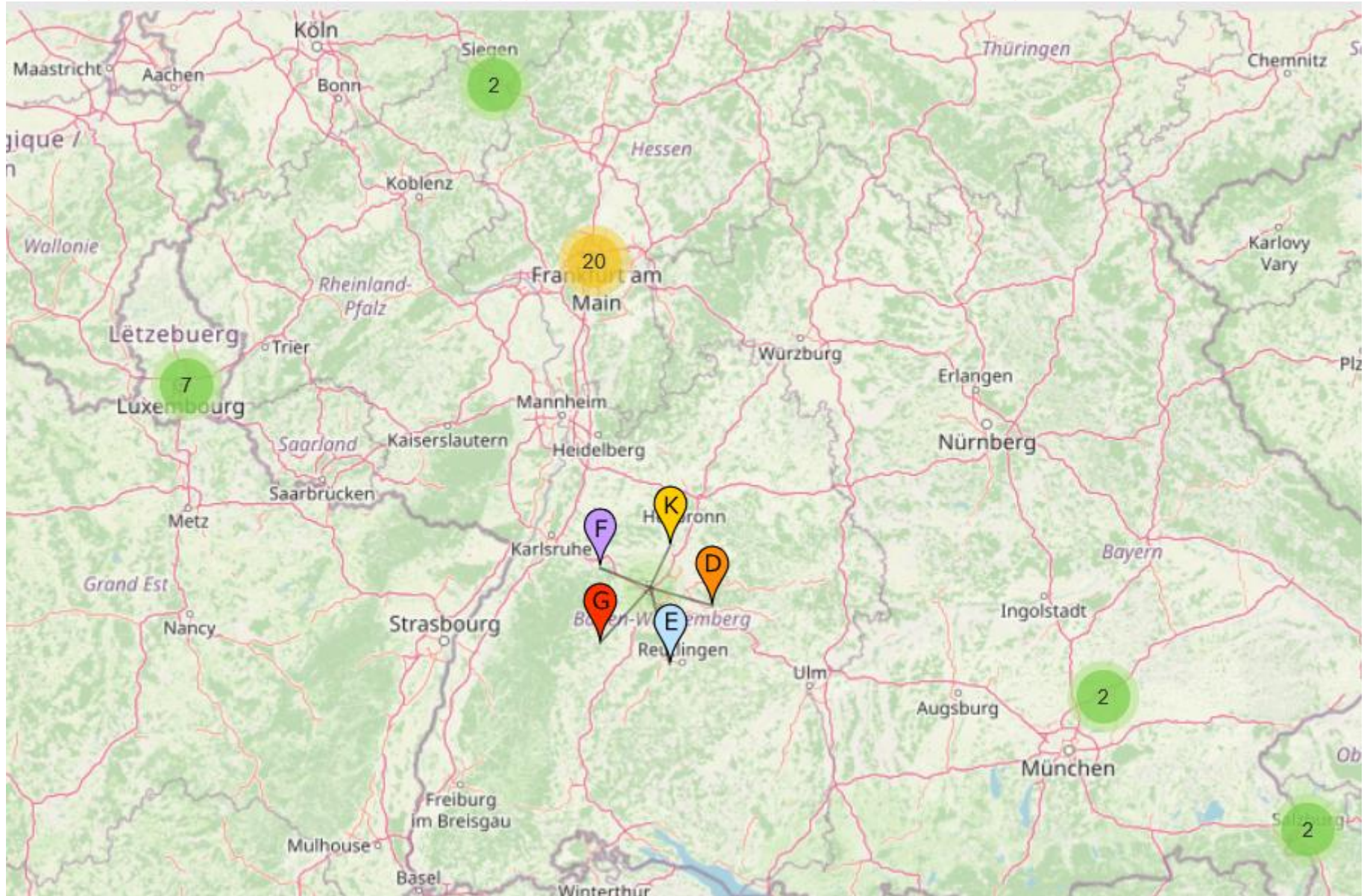


Netzwerksicherheit Techniken DNSSEC

- **DNS-Security-Extensions (DNSSEC)**
 - DNS ist einer der wichtigsten Internetdienste
 - Umsetzung von Domain-Namen in IP-Adressen anhand der Domain-Hierarchie.
 - 13 Root-Server A bis M bilden Wurzel der Hierarchie, verteilt auf derzeit >1900 physische Server weltweit

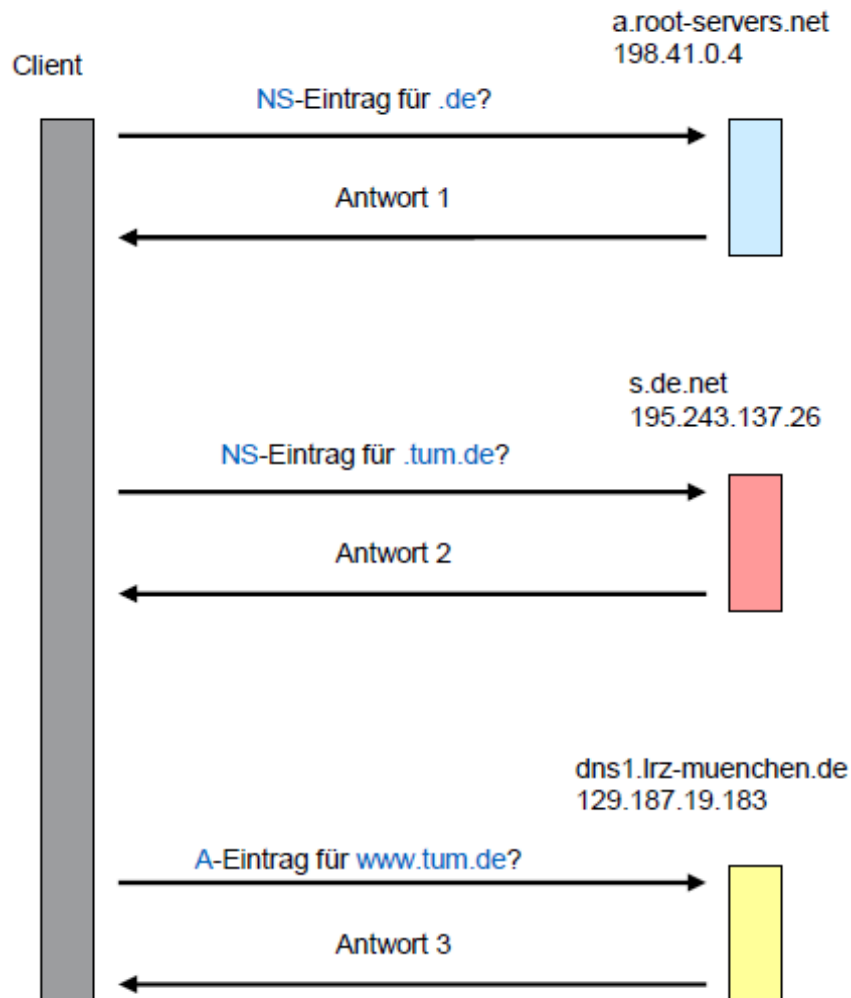


Netzwerksicherheit Techniken DNSSEC Server in DE



Netzwerksicherheit Techniken DNSSEC

- **Beispiel:** Auflösung von `www.tum.de` in IP-Adresse



Antwort 1

```
:: AUTHORITY SECTION:  
de.      IN  NS  a.nic.de.  
de.      IN  NS  c.de.net.  
de.      IN  NS  f.nic.de.  
de.      IN  NS  l.de.net.  
de.      IN  NS  s.de.net.  
de.      IN  NS  z.nic.de.
```

Zuständige
Nameserver

```
:: ADDITIONAL SECTION:  
a.nic.de. IN  A  194.0.0.53  
c.de.net. IN  A  208.48.81.43  
f.nic.de. IN  A  81.91.164.5  
l.de.net. IN  A  77.67.63.105  
s.de.net. IN  A  195.243.137.26  
z.nic.de. IN  A  194.246.96.1
```

Zugehörige
IP-Adressen

```
:: AUTHORITY SECTION:  
tum.de.  IN  NS  dns1.lrz-muenchen.de.  
tum.de.  IN  NS  dns3.lrz-muenchen.de.  
tum.de.  IN  NS  dns2.lrz-muenchen.de.
```

```
:: ADDITIONAL SECTION:  
dns1.lrz-muenchen.de. IN  A  129.187.19.183  
dns2.lrz-muenchen.de. IN  A  141.40.9.211  
dns3.lrz-muenchen.de. IN  A  193.136.2.123
```

```
:: ANSWER SECTION:  
www.tum.de.      IN  CNAME  tum.www.ze.tu-muenchen.de.  
tum.www.ze.tu-muenchen.de. IN  CNAME  tum.www.ze.tum.de.  
tum.www.ze.tum.de.   IN  CNAME  portal.mytum.de.  
portal.mytum.de.     IN  A      129.187.39.3
```

Quelle: [Eck2018]

Netzwerksicherheit Techniken DNSSEC

- DNS Anfrage und Antworten ungeschützt!
 - > DNS-Spoofing
- **DNSSEC, seit 1997 entwickelt! (RFC 4033)**
 - Etablierung einer globalen PKI entlang der Domain-Hierarchie
 - Administrator eines Nameservers signiert die DNS-Einträge in seinem Verwaltungsbereich
 - Empfänger prüft digitale Signatur der DNS-Antworten und kann so Manipulationen erkennen

Netzwerksicherheit Techniken DNSSEC

- **PKI von DNSSEC**

Pro Zone zwei Arten von Public-Key-Schlüssel-Paaren:

- Key-Signing-Key (KSK), empfohlen 2048 Bit, 2-4 Jahre gültig
 - Zone-Signing-Key (ZSK), empfohlen 512 Bit, 1-2 Monate gültig
- ZSK signiert die DNS-Einträge der eigenen Zone
- KSK signiert den Public-ZSK der eigenen Zone
- KSK der übergeordneten Zone signiert den Public-KSK der darunter liegenden Zonen
- Root-Zone selbst ist ebenfalls signiert, Schlüssel wird von VeriSign verwaltet

Netzwerksicherheit Techniken DNSSEC

- Massivste Änderung des DNS in der Geschichte des Internet
 - Root-Zone sowie einige TLDs bereits signiert, Testbetrieb von .de läuft seit 2010
 - Kann Spoofing und Poisoning-Angriffe verhindern
- DNSSEC als Security-Enabler: Globalen, hierarchischen PKI auch für andere Szenarien interessant, Beispiele?
- **Aber:** Viele Endgeräte und Router nach wie vor nicht DNSSEC-fähig, großer Nachholbedarf seitens der Gerätehersteller, z.B. <http://www.ungefiltert-surfen.de/nameserver/de.html>
- <https://blog.apnic.net/2017/12/06/dnssec-deployment-remains-low/>
- <https://rick.eng.br/dnssecstat/> https://stats.dnssec-tools.org/#/?top=tlds&tld_tab=3
 - 2022 91% in TLD, aber nur 6% der 2LD, 30% der User
 - 2026 93% in TLD, 7% 2LD, 36% User (+1% seit 2025), 431.451/17.967.814 Subdomänen in „.de“ 2,4 %

DANE

- Problem bei TLS ist die Vielzahl der zugelassenen Zertifizierungsstellen.
- An dieser Stelle setzt [DNS-based Authentication of Named Entities](#) (DANE) an, um das Zusammenspiel zwischen DNSSEC und TLS zu sichern.
 - In der DNS-Infrastruktur werden auch Zertifikate für TLS mit verwaltet.
- Quellen:
 - <https://www.rfc-editor.org/rfc/rfc6698.html>
 - <https://doku.lrz.de/dane-grundlagen-und-funktionsweise-11491420.html>

Referenzen

- [SCH200x] Schiller, Jochen; Mobilkommunikation; Pearson Studium, 200x, leider vergriffen
- [Les2002] Lescuyer, Pierre; UMTS: Grundlagen, Architektur und Standard, dpunkt, 2002
- [Eck2018] Eckert, Claudia; IT-Sicherheit; deGruyter, 2018, 10. Auflage
- [Eck2023] Eckert, Claudia; IT-Sicherheit; deGruyter, 2023, 11. Auflage